UNIVERSIDAD MARIANO GALVEZ DE GUATEMALA

Facultad de Ingenieria en Sistemas de Informacion

Aseguramiento de la Calidad de Software

MASTER TEST PLAN

Entrega 1 - Estrategia y Base de Pruebas

Sistema evaluado

BancoERP

Sistema Bancario ERP multi-modulo
Banca interna, portal del cliente e interoperabilidad ACH

INTEGRANTES DEL EQUIPO

No.	Nombre completo	Carne	Rol en el equipo QA
1	Luis Alejandro Contreras Paredez	[CARNE]	Lider QA
2	[NOMBRE COMPLETO INTEGRANTE 2]	[CARNE]	Analista de Pruebas
3	[NOMBRE COMPLETO INTEGRANTE 3]	[CARNE]	Tester Funcional
4	[NOMBRE COMPLETO INTEGRANTE 4]	[CARNE]	Tester de Seguridad e Integracion

Dato	Detalle
Equipo	Equipo XX
Docente	[NOMBRE DEL CATEDRATICO]
Curso	Aseguramiento de la Calidad de Software
Actividad	Entrega 1 - Planificacion y Analisis de Pruebas
Version del sistema	Rama main - commit 28f3faf
Fecha de entrega	15 de septiembre de 2026

Guatemala, septiembre de 2026

Control del documento

Version	Fecha	Autor	Descripcion del cambio	Estado
1.0	15-09-2026	Equipo QA XX	Version inicial del Master Test Plan: planificacion y analisis de la base de prueba (Entrega 1).	Emitido

Como leer este documento

Este plan no es un formulario completado. Cada decision de alcance, estrategia y priorizacion esta sustentada en el analisis de la base de prueba realizado sobre el sistema real y, cuando fue posible, verificada de forma empirica sobre el sistema en ejecucion. Los enunciados marcados como 'Verificado' corresponden a comprobaciones efectivamente ejecutadas por el equipo, cuya evidencia se incluye en el Anexo A.

La trazabilidad entre secciones sigue la cadena Requerimiento -> Riesgo -> Prioridad -> Estrategia. Los identificadores (REQ-nn, R-nn, H-nn, BT-nn, DT-nn) son consistentes en todo el documento y permiten recorrer esa cadena en ambos sentidos.

Nota sobre los campos pendientes de la portada

Los campos entre corchetes de la portada ([CARNE], [NOMBRE COMPLETO INTEGRANTE n], [NOMBRE DEL CATEDRATICO] y el numero de equipo) deben completarse antes de la entrega. El resto del documento esta finalizado.

Tabla de contenido

Haga clic derecho aqui y elija 'Actualizar campos' para generar la tabla de contenido.

1. Informacion general del proyecto

1.1 Formato 1 - Informacion del sistema

Elemento	Descripcion
Nombre del sistema	BancoERP (banco-erp-umg)
Descripcion	ERP bancario multi-modulo compuesto por un frontend React 19 + TypeScript (Vite), dos APIs ASP.NET Core 10 (InternalAPI para operacion interna y PublicAPI para interoperabilidad interbancaria ACH), una base de datos PostgreSQL con logica de negocio en stored procedures y una base MongoDB que almacena la configuracion dinamica de los bancos ACH.
Objetivo del sistema	Soportar la operacion bancaria completa: alta de clientes, apertura de cuentas, operaciones de ventanilla (deposito, retiro, transferencia) con control de caja, portal de autoservicio para el cliente final y transferencias interbancarias ACH salientes y entrantes, con registro contable automatico por partida doble y trazabilidad de auditoria.
Usuarios principales	Administrador del sistema, Cajero/Operador de ventanilla, Oficial de negocio (CRM/aprobaciones), Contador, Auditor, Cliente final (portal Mi Banco) y Bancos externos (consumidores de la API publica ACH).
Area de negocio	Banca y servicios financieros - Operaciones, Canales digitales e Interoperabilidad ACH.
Version / Sprint	Rama main - commit 28f3faf. Entrega 1 (Sprint QA 01): Planificacion y Analisis de Pruebas.
Equipo QA	Equipo XX - 4 integrantes con roles de Lider QA, Analista de Pruebas y Testers.
Fecha	15 de septiembre de 2026

1.2 Arquitectura tecnica relevante para las pruebas

La arquitectura condiciona de forma directa la estrategia: la logica de negocio financiera no reside en el codigo de aplicacion sino en procedimientos almacenados de PostgreSQL, y la configuracion del canal ACH vive en una base de datos distinta (MongoDB). Esto explica por que el nivel de integracion se prioriza sobre el nivel de componente en la seccion 8.

Componente	Detalle tecnico
Frontend	React 19 + TypeScript, Vite, Redux Toolkit, React Router. Puerto local 3000.
InternalAPI	ASP.NET Core 10, autenticacion JWT, autorizacion por permisos. Puerto local 5141.
PublicAPI	ASP.NET Core 10, expone /api/external/ach para bancos externos. Puerto local 5254.
Base de datos transaccional	PostgreSQL (Supabase). Esquemas: seguridad, clientes, cuentas, transacciones, caja, contabilidad, auditoria, ach.
Base de datos de configuracion	MongoDB - coleccion banks_configurations con plantillas JSON por banco ACH.
Logica de negocio critica	Stored procedures PostgreSQL: sp_deposito, sp_retiro, sp_transferir_fondos, sp_abrir_cuenta.
Despliegue	Docker Compose (dev) y GitHub Actions CI/CD hacia dos VMs (frontend y backend).

2. Objetivos de las pruebas

2.1 Objetivo general

Planificar y ejecutar un proceso de pruebas basado en riesgos sobre el nucleo transaccional y de seguridad de BancoERP, que permita verificar que las reglas de negocio financieras se aplican de forma uniforme en todos los canales de operacion, detectar defectos que comprometan la integridad del dinero o la confidencialidad de la informacion antes de la liberacion a produccion, y entregar a la gerencia informacion objetiva y medible sobre el nivel de calidad alcanzado.

2.2 Objetivos especificos

ID	Objetivo especifico
OE-01	Verificar que las reglas de negocio de saldo minimo, saldo disponible y limite de retiro diario se apliquen de forma identica en los tres canales que mueven dinero (ventanilla, portal del cliente y ACH), dado que el analisis estatico ya evidencio divergencias entre ellos.
OE-02	Validar el control de acceso basado en permisos (RBAC) de los 84 permisos declarados, confirmando que ningun endpoint que exponga informacion sensible o mueva fondos sea alcanzable sin autenticacion y sin el permiso correspondiente.
OE-03	Evaluar la integridad transaccional y la idempotencia del canal ACH, comprobando que una transferencia entrante no pueda acreditarse dos veces y que toda operacion fallida revierta completamente saldos y registros contables.
OE-04	Identificar, valorar y priorizar los riesgos de producto asociados a la operacion bancaria, utilizando el resultado como criterio para asignar el esfuerzo de pruebas y el orden de ejecucion.
OE-05	Detectar y documentar ambiguedades, omisiones y contradicciones en la base de prueba antes del diseno de casos, para reducir el retrabajo y el numero de defectos de especificacion que llegarian a la fase de ejecucion.

3. Definicion del alcance

El alcance se definio aplicando un criterio unico y explicito: el nivel de riesgo de producto calculado en la seccion 7. Ningun elemento se excluye por falta de importancia; cada exclusion identifica el motivo concreto (riesgo diferido, restriccion de ambiente, limitacion de perfil o decision de priorizacion) y, cuando corresponde, indica con que actividad se sustituye.

3.1 Formato 2 - Elementos In-Scope y Out-of-Scope

Categoria	Modulo / Funcionalidad	Justificacion del negocio	Prioridad
In-Scope	Autenticacion y gestion de sesiones (login, refresh, logout, recuperacion de password)	Es la puerta de entrada a todo el sistema y el unico control que separa a un atacante de los fondos de los clientes. Ademas concentra reglas configurables (bloqueo por intentos, historial de passwords) cuyo valor difiere entre el codigo y el ambiente, lo que ya constituye un defecto de especificacion.	**Critica**
In-Scope	Autorizacion RBAC: roles, permisos y permisos efectivos por usuario	El sistema declara 84 permisos y la UI se construye a partir de ellos. Durante el analisis se detecto al menos un modulo sin declaracion de autorizacion, por lo que la cobertura real del control de acceso no puede asumirse y debe verificarse endpoint por endpoint.	**Critica**

Categoria	Modulo / Funcionalidad	Justificacion del negocio	Prioridad
In-Scope	Sesion de caja: apertura, estado y cierre con cuadre de efectivo	Es precondicion obligatoria de toda operacion de ventanilla: sin caja abierta el sistema rechaza deposito, retiro y transferencia. Un defecto aqui bloquea la operacion completa de la sucursal y afecta el arqueo de efectivo, que tiene impacto contable y de auditoria.	Alta
In-Scope	Transacciones de ventanilla: deposito, retiro y transferencia interna	Mueven dinero real y son el corazon del negocio. La logica reside en stored procedures con multiples validaciones de frontera (saldo minimo, saldo disponible, limite diario) que exigen tecnicas formales de valores limite y particion de equivalencia.	Critica
In-Scope	Portal del cliente (Mi Banco): consulta de cuentas, movimientos y transferencia	Es el canal expuesto al cliente final sin intermediacion de un empleado del banco, por lo que el riesgo de acceso horizontal a cuentas ajenas es alto. Reimplementa en C# la logica de transferencia que en ventanilla vive en la base de datos, duplicidad que exige verificacion comparativa.	Critica
In-Scope	ACH interbancario saliente y entrante (InternalAPI y PublicAPI)	Integra sistemas de terceros fuera del control del equipo y maneja acreditacion de fondos provenientes del exterior. La idempotencia por codigo de confirmacion es la unica barrera contra la doble acreditacion, y es un cambio reciente (commits de mayo 2026) sin cobertura de pruebas de integracion.	Critica
In-Scope	Bitacora de eventos de seguridad y auditoria de operaciones	Requisito regulatorio de trazabilidad en banca. Si la bitacora no registra correctamente los eventos, la institucion pierde la capacidad de investigar fraudes y de demostrar cumplimiento ante un ente supervisor.	Alta
In-Scope	Apertura de cuentas (AHORRO y MONETARIA) y estados de cuenta	Define los parametros que gobiernan todas las transacciones posteriores: saldo minimo por defecto (Q100.00 en AHORRO) y limite de retiro diario (Q5,000.00 en AHORRO). Un error en la parametrizacion inicial se propaga a cada operacion de esa cuenta durante toda su vida.	Alta
Out-of-Scope	Modulo de Contabilidad: plan de cuentas, asientos manuales y reportes contables	Se excluye la operacion manual del modulo porque no forma parte del flujo critico del Sprint y su riesgo de negocio es diferido: un asiento incorrecto se detecta y corrige en el cierre contable mensual, sin perdida inmediata de fondos. No obstante, SI se verifica la generacion automatica de asientos que disparan los stored procedures transaccionales, porque esa si es consecuencia directa del nucleo In-Scope.	Media
Out-of-Scope	Modulo de RRHH: empleados, cargos y turnos	Es un modulo de soporte administrativo que no mueve fondos ni expone datos de clientes. Su unica interseccion con el nucleo (que el operador sea un empleado activo) se cubre indirectamente como precondicion de las pruebas de caja, por lo que probarlo de forma independiente aportaria poco valor frente al costo del esfuerzo.	Baja
Out-of-Scope	Modulo de Catalogos y parametros de configuracion	Es un CRUD de tablas de referencia con bajo nivel de reglas de negocio. Se excluye por decision de priorizacion ante el tiempo limitado del Sprint; los catalogos que si afectan al nucleo (tipos de cuenta) se validan de forma indirecta a traves de la apertura de cuentas.	Baja
Out-of-Scope	Pruebas de rendimiento y carga sostenida sobre la base de datos de produccion	El ambiente de QA comparte la instancia PostgreSQL remota (Supabase) con el equipo de desarrollo. Generar carga sostenida degradaria el trabajo de otros equipos y los resultados no serian representativos por no disponer de un ambiente dimensionado. Se sustituye por pruebas puntuales de concurrencia acotada sobre transacciones criticas.	Media
Out-of-Scope	Pruebas de penetracion y analisis de seguridad ofensiva	Requiere herramientas, autorizacion formal y perfil especializado que el equipo no posee en esta entrega. Se sustituye por verificacion de controles de acceso, revision de dependencias vulnerables y pruebas de seguridad funcional (autenticacion, autorizacion horizontal y vertical).	Media
Out-of-Scope	Compatibilidad multi-	El sistema es de uso interno con parque de equipos	Baja

Categoria	Modulo / Funcionalidad	Justificacion del negocio	Prioridad
	navegador extendida y accesibilidad WCAG	estandarizado en Chrome y Edge. Se acota la verificacion a esos dos navegadores mas una validacion responsive en 390px, en lugar de una matriz completa de navegadores y lectores de pantalla.	

Decision de alcance de mayor impacto

El canal ACH se incorporo al alcance pese a ser el componente de mayor complejidad tecnica y de mayor dependencia externa. La razon es que concentra tres de los riesgos mas altos del sistema (R-01, R-09 y R-10) y ademas es el modulo con cambios mas recientes. Excluirlo habria producido un plan mas comodo de ejecutar pero habria dejado sin cubrir la mayor concentracion de riesgo del producto.

4. Base de prueba

La base de prueba de este proyecto presenta una particularidad que condiciona todo el plan: no existe documentacion funcional formal. En su lugar, el equipo identifico nueve artefactos tecnicos utilizables y cuatro artefactos ausentes. La decision de tratar el codigo fuente y los scripts SQL como base de prueba normativa se documenta y se justifica en la seccion 13.

4.1 Formato 3 - Inventario de la base de prueba

ID	Artefacto	Version / Fecha	Fuente	Estado	Observaciones
BT-01	Codigo fuente del backend (.NET) - Servicios de aplicacion y controladores	commit 28f3faf / 15-09-2026	Repositorio Git - Backend/BancoERP.Application y .InternalAPI	**Disponible**	Fuente primaria y confiable. 21 controladores y 19 servicios revisados. Permite derivar reglas de validacion, codigos HTTP esperados y mensajes de error exactos.
BT-02	Scripts SQL de despliegue - Stored procedures y esquema de datos	deploy/production/ 001 a 015 - 15-09-2026	Repositorio Git - Backend/database/deploy /production	**Disponible**	Contiene las reglas de negocio financieras reales (sp_deposito, sp_retiro, sp_transferir_fondos) con sus valores limite. Es la unica fuente donde estan documentados los defaults de saldo minimo y limite diario. Critico para el diseno de valores frontera.
BT-03	Catalogo de permisos y eventos de seguridad (constantes de dominio)	PermisosSeguridad.cs / EventosSeguridad.cs - 15-09-2026	Repositorio Git - Backend/BancoERP.Domain/Constants	**Disponible**	Define los 84 permisos y los 21 eventos auditables. Sirve como base para la matriz de pruebas de control de acceso y para verificar la completitud de la bitacora.
BT-04	Mapa de rutas y proteccion del frontend (AppRouter y ProtectedRoute)	AppRouter.tsx - 15-09-2026	Repositorio Git - Frontend/src/router	**Disponible**	Permite trazar cada pantalla con el permiso que la protege y detectar divergencias entre la proteccion de la UI y la del API.
BT-05	Documentacion de la API publica ACH (anotaciones OpenAPI/Swagger)	ExternalAchController.cs - 15-09-2026	Swagger en http://localhost:5254/swagger	**Disponible parcialmente**	Es el unico artefacto con ejemplos de request/response y criterios de aceptacion explicitos, pero solo cubre el canal ACH externo. No existe equivalente para la API interna.
BT-06	Script de smoke test funcional automatizado	functional-smoke.mjs - 15-09-2026	Repositorio Git - Frontend/scripts	**Disponible**	Documenta de facto el flujo end-to-end esperado y los datos semilla (usuario admin, banco externo). Se usara como referencia de contrato y como base para los criterios de entrada.
BT-07	Suite de pruebas unitarias existente (xUnit)	13 pruebas - ejecutadas 15-09-2026	Repositorio Git - Backend/BancoERP.UnitTests	**Disponible**	Linea base de regresion verificada: 13/13 exitosas. Cubre unicamente construccion de payload ACH y autorizacion de banco externo. No cubre deposito, retiro, transferencia, caja ni portal.
BT-08	Configuracion de despliegue e integracion continua	docker-compose*.yml, .github/workflows - 15-09-2026	Repositorio Git - raiz del proyecto	**Disponible**	Define el ambiente reproducible y las validaciones automaticas del pipeline. Base para los criterios de entrada relativos a disponibilidad de build y ambiente.

ID	Artefacto	Version / Fecha	Fuente	Estado	Observaciones
BT-09	Sistema en ejecucion (exploracion funcional guiada)	Ejecutado 15-09-2026	Ambiente local Docker - 21 evidencias en Anexo A	Disponible	Suple parcialmente la ausencia de especificacion escrita: permite observar el comportamiento real, los mensajes al usuario y los estados vacios. Se usa como base de prueba complementaria, nunca como sustituto del requerimiento aprobado.
BT-10	Historias de usuario y criterios de aceptacion formales	No aplica	Product Owner / Catedratico	NO DISPONIBLE	BRECHA CRITICA. No existe backlog formal ni criterios de aceptacion escritos. El equipo QA debe inferir el comportamiento esperado desde el codigo, lo que impide detectar defectos de tipo 'el sistema hace algo distinto a lo que el negocio pidio'. Ver hallazgo H-01.
BT-11	Reglas de negocio documentadas por el area de negocio	No aplica	Area de Operaciones del banco	NO DISPONIBLE	BRECHA CRITICA. Los limites financieros (saldo minimo Q100.00, limite diario Q5,000.00) existen solo como valores por defecto dentro del codigo SQL. No hay autoridad de negocio que confirme si son correctos, por lo que QA no puede declarar un defecto cuando el sistema los aplica de forma inconsistente. Ver hallazgos H-02 y H-03.
BT-12	Mockups, prototipos o guia de diseno de interfaz	No aplica	Equipo de diseno	NO DISPONIBLE	No existen mockups aprobados. Las pruebas de usabilidad se limitaran a verificar consistencia interna, comportamiento responsive y claridad de mensajes de error, sin poder contrastar contra un diseno de referencia.
BT-13	Especificacion de requerimientos no funcionales (SLA, rendimiento, retencion)	No aplica	Arquitectura / Negocio	NO DISPONIBLE	No hay tiempos de respuesta objetivo, volumen esperado de transacciones ni politica de retencion de bitacoras. Impide definir criterios de salida medibles para rendimiento. Ver hallazgo H-11.

4.2 Evaluacion de la base de prueba

Dimension evaluada	Resultado del analisis
Informacion disponible y confiable	Codigo fuente completo de backend y frontend, scripts SQL con la logica de negocio real, catalogo de permisos, documentacion Swagger del canal ACH, suite de pruebas unitarias ejecutable y ambiente desplegable con Docker. Sobre esta base SI es posible disenar pruebas objetivas de caja negra y de valores limite.
Informacion faltante	Historias de usuario, criterios de aceptacion formales, reglas de negocio validadas por el area usuaria, mockups y requerimientos no funcionales cuantificados. Cuatro de los trece artefactos de la base de prueba no existen.
Informacion con problemas	El valor del umbral de bloqueo por intentos fallidos aparece con dos valores distintos (3 en el codigo, 5 en la configuracion del ambiente). La regla de limite de retiro diario se implementa de tres maneras distintas segun el canal. El contrato del endpoint de login expone tres campos para identificar al usuario sin documentar cual es obligatorio.
Artefactos que se usaran como base para el diseno de pruebas	BT-01, BT-02 y BT-03 como fuente normativa principal (definen el comportamiento verificable); BT-05 y BT-06 como contrato de interfaces; BT-04 y BT-09 para el diseno de pruebas de interfaz de usuario; BT-07 como linea base de regresion. Las brechas BT-10, BT-11 y BT-13 se gestionan como riesgo de proyecto y se escalan al PO mediante los hallazgos H-01, H-02 y H-11.

5. Analisis de la base de prueba

Esta seccion responde, requerimiento por requerimiento, a la pregunta fundamental del analisis de pruebas: un tester, con la informacion disponible hoy, puede disenar una prueba objetiva de este requerimiento? Cuando la respuesta es negativa, se explica el motivo y se propone la accion concreta que lo haria verificable.

De los 24 requerimientos revisados, unicamente 7 resultaron simultaneamente claros, completos, verificables y consistentes. Los criterios aplicados fueron: Claro (admite una unica interpretacion), Completo (incluye entradas, reglas y resultado esperado), Verificable (permite un veredicto objetivo de aprobado o fallido) y Consistente (no contradice a otro requerimiento ni a otra parte del sistema).

5.1 Formato 4 - Revision de requerimientos

ID	Requerimiento	Claro	Compl.	Verif.	Consis.	Problema detectado	Accion recomendada
REQ-01	Autenticar al usuario con nombre de usuario o correo y contrasena, devolviendo un token JWT y un refresh token.	No	No	Si	No	El contrato expone tres campos (Email, Password, Username) y deriva internamente un 'Identificador'. No se documenta cual es obligatorio: un cliente que envie el campo 'identificador' recibe HTTP 400 aunque la UI rotule el campo como 'Usuario o correo'. Verificado: POST con {username} responde 200 y POST con {identificador} responde 400.	Solicitar al PO la definicion formal del contrato de login y unificar el nombre del campo. Hasta entonces, disenar pruebas contra el comportamiento observado y registrar la ambiguedad como hallazgo H-04.
REQ-02	Bloquear al usuario tras N intentos fallidos consecutivos de inicio de sesion.	No	No	Si	No	El valor de N no esta especificado en ningun requerimiento. El codigo usa 3 como valor por defecto y la configuracion del ambiente define 5, por lo que el comportamiento depende del despliegue. Ademas no se define la duracion del bloqueo ni el procedimiento de desbloqueo.	Escalar al PO para fijar N, la duracion del bloqueo y el mecanismo de desbloqueo. QA no puede declarar un resultado esperado sin ese dato. Ver hallazgo H-02.
REQ-03	Exigir contrasenas de al menos 8 caracteres con mayusculas, minusculas y numeros, e impedir la reutilizacion de las ultimas N.	Si	No	Si	Si	La regla de composicion es explicita y verificable en el codigo, pero no se exige caracter especial ni se define vigencia maxima de la contrasena. El tamano del historial (5) es configurable y no esta especificado por el negocio.	Confirmar con el negocio si la politica cumple la normativa bancaria aplicable. Disenar pruebas de valores limite sobre longitud (7, 8, 9 caracteres) y sobre el historial (N y N+1).
REQ-04	Permitir la recuperacion de contrasena mediante un token temporal de un solo uso.	Si	No	No	Si	El endpoint devuelve el token de recuperacion en el cuerpo de la respuesta HTTP. No existe requerimiento que defina el canal de entrega (correo, SMS), por lo que no es verificable si el comportamiento actual es una decision de diseno para el ambiente academico o un defecto de seguridad.	Aclarar con el PO el canal de entrega esperado. Si debe ser por correo, el comportamiento actual es un defecto critico de exposicion de credenciales.
REQ-05	Renovar la sesion mediante refresh token con rotacion, y revocar todas las sesiones al cambiar la contrasena.	Si	Si	Si	Si	Sin problemas relevantes. El comportamiento es deducible sin ambiguedad: rotacion de token en cada renovacion y revocacion masiva de sesiones en el cambio de contrasena.	Disenar pruebas de reutilizacion de refresh token revocado y de invalidacion de sesiones activas tras el cambio de contrasena.
REQ-06	Restringir cada operacion del sistema segun los permisos efectivos del usuario autenticado.	Si	No	Si	No	El mecanismo esta definido, pero su aplicacion no es uniforme: los controladores de bancos ACH y de transferencias ACH internas no declaran atributo de autorizacion alguno, y la aplicacion no define una politica de autorizacion por defecto. Verificado: GET /api/ach/bancos responde HTTP 200 sin token, mientras GET /api/clientes responde 401.	Reportar como defecto critico de seguridad (H-05) antes de iniciar la ejecucion. Disenar una matriz de control de acceso que recorra los 84 permisos con usuario sin token, con token sin permiso y con permiso.
REQ-07	Registrar en bitacora todo evento de seguridad relevante con usuario, IP, agente y resultado.	Si	No	Si	Si	Los 21 tipos de evento estan catalogados, pero no se define la politica de retencion de la bitacora ni si debe ser inmutable, ambos requisitos habituales en banca.	Solicitar al negocio la politica de retencion e inmutabilidad. Disenar pruebas que verifiquen que cada evento catalogado se persiste efectivamente al ejecutar la accion correspondiente.
REQ-08	Permitir al operador abrir una sesion de	Si	No	Si	Si	No se especifica si un mismo operador puede tener mas de una caja abierta simultaneamente, ni si existe un monto maximo o minimo para el fondo	Definir con Operaciones las restricciones de apertura. Disenar pruebas de valores limite sobre el fondo inicial y

ID	Requerimiento	Claro	Compl.	Verif.	Consis.	Problema detectado	Accion recomendada
	caja registrando un fondo inicial.					inicial, ni el comportamiento ante fondo inicial cero o negativo.	de intento de doble apertura.
REQ-09	Permitir el cierre de caja calculando el efectivo esperado como fondo inicial mas depositos menos retiros.	Si	No	No	Si	La formula esta visible en la interfaz, pero no se define que debe ocurrir ante un descuadre entre el efectivo declarado y el esperado: si el cierre se bloquea, se permite con justificacion o se registra una diferencia. Sin esa definicion no existe un resultado esperado objetivo.	Escalar al area de Operaciones. Es la definicion mas urgente del modulo de caja porque determina el resultado esperado de todo el conjunto de pruebas de cierre. Ver hallazgo H-07.
REQ-10	Registrar un deposito en una cuenta activa, exigiendo operador con caja abierta y monto mayor a cero.	Si	Si	Si	Si	Sin problemas relevantes. Las validaciones son explicitas en el stored procedure: monto mayor a cero, sesion de caja abierta, cuenta existente y en estado ACTIVA.	Disenar pruebas de particion de equivalencia y valores limite sobre el monto (0, 0.01, negativo, decimales con mas de dos posiciones) y sobre los estados de cuenta no activos.
REQ-11	Registrar un retiro validando saldo disponible, saldo minimo y limite de retiro diario.	No	No	Si	No	El limite de retiro diario se aplica unicamente a las cuentas de tipo AHORRO; las cuentas MONETARIA quedan sin limite aunque tengan el campo configurado. No existe requerimiento que justifique esa diferencia, por lo que no se puede determinar si es una regla de negocio deliberada o un defecto.	Confirmar con el negocio si la exencion de las cuentas MONETARIA es intencional. Es insumo directo del hallazgo H-03.
REQ-12	Registrar una transferencia entre dos cuentas internas validando que origen y destino sean distintos.	No	No	Si	No	El procedimiento de transferencia no valida ni acumula el limite de retiro diario: verificado que sp_transferir_fondos no contiene ninguna referencia a limite_retiro_diario ni a monto_retirado_hoy, mientras que sp_retiro si las contiene. Un cliente puede evadir el limite diario transfiriendo en lugar de retirar. Ademas, la misma operacion aplica reglas distintas segun el canal.	Reportar como defecto de reglas de negocio de severidad alta (H-03) antes del diseno de casos. Disenar pruebas comparativas que ejecuten la misma operacion en los tres canales y contrasten resultados.
REQ-13	Consultar el historial de movimientos de una cuenta de forma paginada.	Si	Si	Si	Si	Sin problemas relevantes. El tamano de pagina se normaliza con un maximo de 100 registros y valores por defecto definidos.	Disenar pruebas de valores limite sobre la paginacion (pagina 0, negativa, tamano 0, 100, 101) y verificar el orden descendente por fecha.
REQ-14	Abrir una cuenta de tipo AHORRO o MONETARIA para un cliente activo, con parametros por defecto segun el tipo.	Si	No	Si	Si	Los valores por defecto (saldo minimo Q100.00 y limite diario Q5,000.00 para AHORRO) existen unicamente en el codigo SQL. No hay confirmacion del area de negocio de que esos importes sean los correctos, por lo que QA no tiene una autoridad contra la cual comparar.	Solicitar validacion formal de los parametros financieros por defecto. Sin esa confirmacion las pruebas solo pueden verificar consistencia interna, no correccion de negocio.
REQ-15	Mostrar al cliente autenticado unicamente el resumen, cuentas y movimientos que le pertenecen.	Si	Si	Si	Si	Sin problemas relevantes en la especificacion. La restriccion por cliente esta implementada de forma explicita en las consultas.	Disenar pruebas de acceso horizontal: intentar consultar cuentas y movimientos de otro cliente manipulando identificadores en la peticion.
REQ-16	Permitir al cliente transferir fondos desde el portal validando propiedad de la cuenta, estados, saldo y limite diario.	Si	Si	Si	No	La logica esta completa y es la mas estricta de los tres canales, pero esta reimplementada en C# en lugar de reutilizar el procedimiento almacenado. Aplica el limite diario a cualquier tipo de cuenta, a diferencia del retiro en ventanilla que solo lo aplica a AHORRO. Misma regla de negocio, tres implementaciones divergentes.	Reportar la duplicidad como deuda tecnica con impacto en pruebas (H-03): obliga a duplicar los casos de prueba por canal en lugar de probar una unica implementacion.
REQ-17	Administrar la configuracion dinamica de bancos ACH externos con plantillas JSON de peticion.	No	No	No	No	La respuesta del servicio incluye el campo de contrasena de integracion en texto plano, y el endpoint no exige autenticacion. No existe requerimiento que defina como deben protegerse las credenciales de los bancos socios. No es verificable porque no hay comportamiento esperado definido.	Elevar a defecto critico de seguridad (H-05). Requiere decision de arquitectura sobre cifrado y enmascaramiento antes de poder disenar la prueba.
REQ-18	Enviar una transferencia ACH a un banco externo generando un codigo de confirmacion unico.	No	No	No	No	El comportamiento depende de la plantilla JSON que cada banco externo configure en MongoDB, por lo que el resultado esperado es variable y no esta acotado. No se define el comportamiento ante indisponibilidad del banco destino, ni politica de reintentos, ni tiempo maximo de espera, ni estado final de la transferencia en caso de timeout.	Solicitar la especificacion del manejo de fallos de integracion. Es el requerimiento menos verificable del alcance y el de mayor riesgo economico. Ver hallazgo H-06.
REQ-19	Acreditar una transferencia ACH entrante de forma idempotente, rechazando codigos de confirmacion	Si	Si	Si	Si	Es el requerimiento mejor especificado del sistema: la documentacion Swagger define ejemplos de peticion, respuesta exitosa y respuesta duplicada, con codigos HTTP explicitos. Sirve como modelo de lo que	Disenar pruebas de idempotencia (envio duplicado concurrente y secuencial), de moneda no soportada y de tipo de operacion distinto de ENTRANTE.

ID	Requerimiento	Claro	Compl.	Verif.	Consis.	Problema detectado	Accion recomendada
	duplicados.					deberia existir para el resto de requerimientos.	
REQ-20	Autenticar bancos externos con el rol BANCO_EXTERNO y emitir un token limitado a operaciones ACH publicas.	Si	Si	Si	Si	Sin problemas relevantes. Es el unico requerimiento con cobertura de pruebas unitarias verificada (usuario sin rol rechazado, usuario interno rechazado, permiso ausente rechazado).	Reutilizar las pruebas unitarias existentes como regresion y complementar con pruebas de integracion sobre el endpoint real.
REQ-21	Generar automaticamente los asientos contables por partida doble de cada transaccion.	No	No	Si	Si	La generacion depende de la existencia previa de cuentas contables activas en el plan de cuentas (codigos 1101, 2101). Si no existen, el procedimiento lanza excepcion y la transaccion completa falla. Esta dependencia no esta documentada como precondicion en ningun requerimiento funcional.	Documentar la dependencia como precondicion de datos obligatoria en el ambiente de pruebas e incluirla en los criterios de entrada.
REQ-22	Restringir el consumo de las APIs a los origenes autorizados mediante CORS.	Si	Si	Si	Si	Sin problemas. Verificado que el analizador de configuracion acepta origenes separados por coma y por punto y coma, por lo que la configuracion actual del ambiente es valida.	Verificar en pruebas que un origen no autorizado sea efectivamente rechazado por el navegador.
REQ-23	Desplegar el sistema de forma reproducible mediante contenedores e integracion continua.	Si	No	Si	Si	El pipeline esta definido, pero no se especifica un umbral de cobertura ni una politica de bloqueo de despliegue ante pruebas fallidas o dependencias vulnerables. Actualmente el build emite advertencias de vulnerabilidad conocida y aun asi completa exitosamente.	Proponer al equipo de desarrollo la incorporacion de una compuerta de calidad en el pipeline. Ver hallazgo H-09.
REQ-24	Presentar una interfaz usable en escritorio y dispositivos moviles, con modo claro y oscuro.	No	No	No	Si	No existe requerimiento que defina resoluciones objetivo, navegadores soportados ni criterios de aceptacion de usabilidad. Sin mockups aprobados no hay referencia contra la cual comparar, por lo que un tester no puede emitir un veredicto objetivo de aprobado o fallido.	Acotar el alcance a verificacion de consistencia interna y ausencia de defectos evidentes de maquetacion en dos resoluciones definidas por el equipo, dejando constancia de la limitacion.

5.2 Sintesis del analisis

Resultado del analisis	Cantidad	Requerimientos
Claros, completos, verificables y consistentes	7	REQ-05, REQ-10, REQ-13, REQ-15, REQ-19, REQ-20, REQ-22
Con ambiguedades (admiten mas de una interpretacion)	7	REQ-01, REQ-04, REQ-06, REQ-11, REQ-14, REQ-17, REQ-21
Incompletos (falta informacion para definir el resultado esperado)	9	REQ-02, REQ-03, REQ-07, REQ-08, REQ-09, REQ-16, REQ-18, REQ-23, REQ-24
No verificables (imposible emitir un veredicto objetivo)	5	REQ-04, REQ-09, REQ-17, REQ-18, REQ-24
Con defecto ya confirmado durante el analisis	3	REQ-06 y REQ-17 (control de acceso, H-05); REQ-12 (limite diario, H-03)

El hallazgo mas relevante de esta seccion

Tres requerimientos criticos (REQ-02, REQ-09 y REQ-18) carecen hoy de un resultado esperado objetivo, porque el negocio no ha definido el umbral de bloqueo, el comportamiento ante descuadre de caja ni el manejo de fallos en la integracion ACH. Ningun caso de prueba disenado sobre ellos seria valido: el tester no podria determinar si el comportamiento observado es correcto. Por esa razon estas definiciones se incorporaron como criterio de entrada bloqueante en la seccion 10.

6. Matriz de trazabilidad de requerimientos (RTM)

La matriz vincula cada requerimiento con su fuente en la base de prueba, su criterio de aceptacion, su estado de analisis y el riesgo asociado. En las siguientes entregas se extendera hacia la derecha para incorporar condicion de prueba, caso de prueba y resultado de ejecucion, completando la cadena de trazabilidad definida en la seccion 13.

ID	Descripcion	Prior.	Fuente	Criterio de aceptacion	Estado del analisis	Riesgo	Observaciones
REQ-01	Autenticacion de usuario interno con emision de JWT y refresh token	Alta	BT-01	Con credenciales validas responde 200 con token, refresh y permisos; con invalidas responde 401 sin emitir token	Con ambiguedades	R-02	Contrato de entrada ambiguo. Bloquea el diseno del caso negativo de campo faltante.
REQ-02	Bloqueo de usuario por intentos fallidos consecutivos	Alta	BT-01	PENDIENTE DE DEFINICION: el umbral N no esta especificado por el negocio	Incompleto	R-02	No se puede disenar el caso hasta que el PO fije N y la duracion del bloqueo.
REQ-03	Politica de composicion e historial de contrasenas	Media	BT-01	Rechaza contrasenas de menos de 8 caracteres o sin mayuscula, minuscula o digito; rechaza las ultimas 5 usadas	Analizado	R-02	Verificable con valores limite. Falta confirmar exigencia de caracter especial.
REQ-04	Recuperacion de contrasena mediante token temporal	Media	BT-01	Genera token de un solo uso con expiracion; token usado o vencido es rechazado	Con ambiguedades	R-02	El canal de entrega del token no esta definido. Posible exposicion.
REQ-05	Rotacion de refresh token y revocacion de sesiones	Alta	BT-01	El refresh token anterior queda invalido tras la rotacion; el cambio de contrasena revoca toda sesion activa	Analizado	R-02	Requerimiento completo y verificable sin aclaraciones.
REQ-06	Autorizacion granular por permisos efectivos	Critica	BT-01, BT-03	Toda peticion sin token responde 401 y toda peticion sin el permiso requerido responde 403	Defecto detectado	R-01	Incumplido en el modulo ACH: verificado 200 sin autenticacion. Origen de H-05.
REQ-07	Bitacora de eventos de seguridad	Alta	BT-03	Cada uno de los 21 eventos catalogados se persiste con usuario, IP, agente, resultado y fecha	Analizado	R-07	Falta politica de retencion e inmutabilidad.
REQ-08	Apertura de sesion de caja con fondo inicial	Alta	BT-01, BT-09	Crea una sesion activa para el operador; sin caja abierta las operaciones de ventanilla se rechazan con 422	Incompleto	R-06	Falta definir doble apertura y limites del fondo inicial.
REQ-09	Cierre de caja con cuadre de efectivo	Alta	BT-09	PENDIENTE DE DEFINICION: no se especifica el comportamiento ante descuadre	Incompleto	R-06	Sin resultado esperado objetivo. Origen de H-07.
REQ-10	Deposito en ventanilla	Critica	BT-02	Acredita el monto, devuelve referencia y saldo nuevo, y genera el asiento contable correspondiente	Analizado	R-03	Reglas completas y verificables en sp_deposito.
REQ-11	Retiro en ventanilla con validacion de saldo y limite diario	Critica	BT-02	Rechaza si el saldo disponible es insuficiente, si deja el saldo bajo el minimo o si excede el limite diario en cuentas AHORRO	Con ambiguedades	R-03, R-04	La exencion de las cuentas MONETARIA no esta justificada. Insumo de H-03.
REQ-12	Transferencia interna en ventanilla	Critica	BT-02	Debita origen, acredita destino y rechaza si origen y destino coinciden o el saldo es insuficiente	Defecto detectado	R-04	No aplica ni acumula limite diario. Permite evadir el control. Origen de H-03.
REQ-13	Consulta paginada de historial de movimientos	Media	BT-01	Devuelve los movimientos de la cuenta ordenados por fecha descendente, con maximo 100 por pagina	Analizado	R-08	Verificable con valores limite de paginacion.
REQ-14	Apertura de cuenta AHORRO o MONETARIA	Alta	BT-02	Crea la cuenta solo si el cliente esta ACTIVO, aplicando saldo minimo y limite diario segun el tipo	Con ambiguedades	R-04	Los importes por defecto no estan validados por el negocio.
REQ-15	Consulta de cuentas y movimientos propios en el portal	Critica	BT-01	El cliente solo obtiene informacion de las cuentas asociadas a su propio identificador de cliente	Analizado	R-05	Requiere pruebas de acceso horizontal.
REQ-16	Transferencia desde el portal del cliente	Critica	BT-01	Valida propiedad de la cuenta origen, estado ACTIVO de cliente y cuentas, saldo disponible, saldo minimo y	Analizado	R-04, R-05	Implementacion divergente respecto de ventanilla. Insumo de H-03.

ID	Descripcion	Prior.	Fuente	Criterio de aceptacion	Estado del analisis	Riesgo	Observaciones
				limite diario			
REQ-17	Administracion de configuracion de bancos ACH	Critica	BT-01	PENDIENTE DE DEFINICION: no se especifica la proteccion de las credenciales de integracion	Defecto detectado	R-01	Expone contrasenas en texto plano sin autenticacion. Origen de H-05.
REQ-18	Envio de transferencia ACH saliente	Critica	BT-01	PENDIENTE DE DEFINICION: no se especifica el manejo de indisponibilidad del banco destino	Incompleto	R-09	El mas alto riesgo economico y el menos verificable. Origen de H-06.
REQ-19	Recepcion idempotente de ACH entrante	Critica	BT-05	Un codigo de confirmacion ya procesado es rechazado sin acreditar fondos por segunda vez	Analizado	R-10	Unico requerimiento con criterios de aceptacion formales documentados.
REQ-20	Autenticacion de banco externo con rol BANCO_EXTERNO	Alta	BT-05, BT-07	Solo usuarios con el rol y el permiso especifico obtienen token; usuarios internos son rechazados	Analizado	R-01	Cubierto por pruebas unitarias existentes (linea base de regresion).
REQ-21	Generacion automatica de asientos contables	Alta	BT-02	Cada transaccion genera su asiento por partida doble contra el plan de cuentas	Con ambiguedades	R-03	Depende de datos maestros contables preexistentes. Precondicion no documentada.
REQ-22	Restriccion de origenes mediante CORS	Media	BT-01	Solo los origenes declarados en la configuracion pueden consumir las APIs desde un navegador	Analizado	R-01	Configuracion verificada como valida.
REQ-23	Despliegue reproducible con contenedores e integracion continua	Media	BT-08	El pipeline construye, levanta el entorno y ejecuta el smoke funcional sin errores	Incompleto	R-12	Sin compuerta de calidad ante dependencias vulnerables. Origen de H-09.
REQ-24	Interfaz usable y responsive con modo claro y oscuro	Baja	BT-04, BT-09	PENDIENTE DE DEFINICION: no existen criterios de usabilidad ni mockups de referencia	Incompleto	R-13	Alcance acotado a consistencia interna y dos resoluciones.

Los criterios de aceptacion marcados como PENDIENTE DE DEFINICION no son una omision del equipo QA: reflejan que el negocio no ha definido el comportamiento esperado. Documentarlos de esa forma, en lugar de inventar un criterio plausible, es lo que permite escalarlos como hallazgo y obtener la definicion antes de disenar los casos.

7. Analisis y priorizacion de riesgos

Los riesgos se valoraron aplicando la formula Nivel de riesgo = Probabilidad x Impacto, con escalas de 1 a 5 en cada factor. La probabilidad se estimo a partir de evidencia concreta del sistema (resultados del analisis estatico, verificaciones sobre el sistema en ejecucion e historial de cambios del repositorio) y no a partir de percepciones generales. El impacto se valoro desde la perspectiva del negocio bancario: perdida economica, incumplimiento regulatorio, interrupcion de la operacion y dano reputacional.

Puntaje	Nivel	Consecuencia sobre la estrategia de pruebas
1 - 5	**Bajo**	Verificacion de humo. Se ejecuta al final del ciclo y es lo primero que se sacrifica si el tiempo se agota.
6 - 10	**Medio**	Particion de equivalencia sobre los escenarios principales. Ejecucion en el ciclo 1 sin revision por pares.
11 - 15	**Alto**	Valores limite y transicion de estados. Ejecucion temprana y registro detallado de evidencia.
16 - 25	**Critico**	Valores limite, tabla de decision y pruebas negativas exhaustivas. Ejecucion prioritaria, asignada al tester con mayor experiencia y con revision por pares.

7.1 Formato 6 - Matriz de riesgos

ID	Riesgo	P	I	Nivel	Prioridad	Justificacion de la valoracion
R-01	Exposicion de endpoints e informacion sensible por ausencia de control de autorizacion uniforme	5	5	25 - Critico	**Maxima**	Probabilidad maxima porque no es una hipotesis: se verifico durante el analisis que GET /api/ach/bancos responde HTTP 200 sin token y que su respuesta incluye la contrasena de integracion de los bancos socios en texto plano. Impacto maximo porque esas credenciales permiten a un tercero suplantar al banco frente a sus contrapartes, con perdida economica directa y dano reputacional y regulatorio.
R-02	Compromiso de credenciales de usuario por debilidades en el flujo de autenticacion	3	5	15 - Alto	**Alta**	Probabilidad media: existen controles reales (BCrypt, bloqueo por intentos, historial de contrasenas), pero el mensaje de error revela el numero de intento sobre el total y el sistema distingue con codigos HTTP distintos al usuario inexistente, inactivo y bloqueado, lo que facilita la enumeracion de cuentas validas. Impacto maximo porque una credencial comprometida da acceso directo a fondos de terceros.
R-03	Perdida de integridad del saldo o del registro contable ante fallos parciales de transaccion	3	5	15 - Alto	**Alta**	Probabilidad media: las operaciones de ventanilla se ejecutan dentro de stored procedures, lo que da atomicidad, pero el asiento contable depende de datos maestros que pueden no existir y la ruta del portal gestiona la transaccion manualmente en codigo de aplicacion. Impacto maximo: un descuadre entre saldo y contabilidad en una institucion financiera es un hallazgo de auditoria grave.
R-04	Evasion de los limites financieros por aplicacion inconsistente de las reglas entre canales	5	4	20 - Critico	**Maxima**	Probabilidad maxima porque esta confirmado por analisis estatico: sp_transferir_fondos no contiene ninguna referencia a limite_retiro_diario ni a monto_retirado_hoy, mientras sp_retiro y el servicio del portal si las aplican. Un cliente evade el limite diario simplemente transfiriendo en vez de retirar. Impacto alto: perdida de un control antifraude, aunque no implica perdida directa de fondos del banco.
R-05	Acceso horizontal de un cliente a cuentas, movimientos o transferencias de otro cliente	2	5	10 - Medio	**Media**	Probabilidad baja porque el portal filtra de forma explicita por el identificador del cliente autenticado en cada consulta y valida la propiedad de la cuenta origen antes de transferir. Impacto maximo por violacion del secreto bancario y posible disposicion de fondos ajenos.
R-06	Bloqueo de la operacion de sucursal o descuadre de efectivo por defectos en el control de caja	4	3	12 - Alto	**Alta**	Probabilidad alta: la caja es precondicion obligatoria de toda operacion de ventanilla y su regla de cierre ante descuadre no esta definida, por lo que el comportamiento actual no puede considerarse

ID	Riesgo	P	I	Nivel	Prioridad	Justificacion de la valoracion
						correcto ni incorrecto. Impacto medio: detiene la atencion al publico y genera diferencias de arqueo, pero es detectable y corregible en el dia.
R-07	Perdida de trazabilidad para investigacion de fraude o requerimiento regulatorio	2	4	8 - Medio	Media	Probabilidad baja porque el catalogo de 21 eventos de seguridad esta implementado y se registra de forma sistematica en el flujo de autenticacion. Impacto alto porque la ausencia de bitacora confiable impide responder ante un ente supervisor y demostrar el cumplimiento normativo.
R-08	Degradacion del rendimiento en consultas de historial y reportes al crecer el volumen	3	2	6 - Medio	Media	Probabilidad media: las consultas estan paginadas con un tope de 100 registros, lo que mitiga el riesgo, pero no hay indices verificados para los filtros por fecha ni volumetria conocida. Impacto bajo porque degrada la experiencia sin comprometer la integridad del dinero.
R-09	Fondos debitados sin acreditar en el banco destino ante fallo de la integracion ACH saliente	4	5	20 - Critico	Maxima	Probabilidad alta porque depende de sistemas de terceros fuera del control del equipo y no existe especificacion de reintentos, tiempo maximo de espera ni estado final ante timeout. Impacto maximo porque el dinero puede salir de la cuenta del cliente sin llegar a destino y sin un procedimiento definido de conciliacion o reverso.
R-10	Doble acreditacion de una transferencia ACH entrante por fallo de idempotencia	2	5	10 - Medio	Media	Probabilidad baja porque la idempotencia por codigo de confirmacion esta implementada y documentada con ejemplos explicitos. Impacto maximo porque acreditar dos veces genera dinero inexistente en el balance del banco, con perdida economica directa e irrecuperable si el cliente dispone de los fondos.
R-11	Diseno de pruebas sobre supuestos incorrectos por ausencia de requerimientos formales	5	3	15 - Alto	Alta	Probabilidad maxima: cuatro de los trece artefactos de la base de prueba no existen, incluidos las historias de usuario y las reglas de negocio validadas. QA esta infiriendo el comportamiento esperado desde el codigo. Impacto medio porque produce falsos negativos (se valida que el sistema hace lo que el codigo dice, no lo que el negocio necesita) y retrabajo, pero es gestionable mediante escalamiento.
R-12	Vulnerabilidades introducidas por dependencias de terceros no actualizadas	4	3	12 - Alto	Alta	Probabilidad alta porque esta confirmado en la salida de compilacion: Snappier 1.0.0 y Microsoft.OpenApi 2.4.1 con vulnerabilidades de severidad alta y SharpCompress 0.30.1 de severidad moderada, y el pipeline no bloquea el despliegue ante esas advertencias. Impacto medio porque la explotabilidad real depende del uso concreto que el sistema hace de cada libreria.
R-13	Defectos de usabilidad o maquetacion no detectables por ausencia de diseno de referencia	3	1	3 - Bajo	Baja	Probabilidad media por la cantidad de pantallas y la reciente incorporacion del modo oscuro y los ajustes responsive. Impacto muy bajo porque no compromete la integridad de los datos ni la seguridad; afecta unicamente la experiencia del operador.
R-14	Indisponibilidad del ambiente de pruebas por dependencia de una base de datos remota compartida	4	3	12 - Alto	Alta	Probabilidad alta porque el ambiente de desarrollo apunta a una instancia PostgreSQL remota en Supabase compartida con el equipo de desarrollo, sin aislamiento para QA. Impacto medio: detiene la ejecucion de pruebas y puede invalidar resultados por modificaciones concurrentes de datos, pero no afecta produccion.
R-15	Resultados de prueba no reproducibles por ausencia de datos de prueba controlados	5	2	10 - Medio	Media	Probabilidad maxima porque esta observado: el ambiente levantado muestra el tablero sin datos, cero bancos ACH configurados y la base MongoDB vacia, por lo que ningun escenario de negocio puede ejecutarse hoy. Impacto bajo porque se resuelve ejecutando los scripts semilla ya existentes en el repositorio, pero es condicion de entrada obligatoria.

7.2 Distribucion y lectura de los riesgos

Nivel	Cant.	Riesgos (puntaje P x I)	Lectura del resultado
Critico (16-25)	3	R-01 (25), R-04 (20), R-09 (20)	Dos de los tres (R-01 y R-04) no son riesgos potenciales sino defectos ya confirmados durante el analisis. Concentran la

Nivel	Cant.	Riesgos (puntaje P x I)	Lectura del resultado
			prioridad maxima de ejecucion.
Alto (11-15)	6	R-02 (15), R-03 (15), R-11 (15), R-06 (12), R-12 (12), R-14 (12)	Concentrados en seguridad de credenciales, integridad transaccional, calidad de la base de prueba y estabilidad del ambiente.
Medio (6-10)	5	R-05 (10), R-10 (10), R-15 (10), R-07 (8), R-08 (6)	Incluyen dos riesgos de impacto maximo pero probabilidad baja (R-05 y R-10), cuyos controles ya estan implementados y solo requieren verificacion.
Bajo (1-5)	1	R-13 (3)	Sin impacto sobre la integridad del dinero ni sobre la seguridad. Ultimo en el orden de ejecucion.

Los tres riesgos criticos concentran aproximadamente el 50% del esfuerzo de pruebas planificado. Esta concentracion es deliberada y responde al principio ISTQB de agrupamiento de defectos: un numero reducido de modulos suele contener la mayoria de los defectos, y en este sistema el analisis ya identifico cuales son.

8. Estrategia de pruebas

8.1 Formato 7 - Definicion de la estrategia

Elemento	Definicion y justificacion
Enfoque de pruebas	Enfoque analitico basado en riesgos, complementado con un enfoque basado en la experiencia mediante pruebas exploratorias. Se elige el enfoque analitico porque el equipo dispone de una base de prueba tecnica solida (codigo y stored procedures) que permite derivar condiciones de prueba objetivas; se complementa con exploracion porque la ausencia de historias de usuario deja zonas del comportamiento esperado sin especificar, y la exploracion es la tecnica indicada para descubrir defectos en ausencia de especificacion.
Basado en riesgos	El nivel de riesgo calculado en la matriz determina tres decisiones concretas: la profundidad de las tecnicas aplicadas (los riesgos criticos reciben valores limite, tabla de decision y transicion de estados; los medios solo particion de equivalencia; los bajos, verificacion de humo), el orden de ejecucion (descendente por nivel de riesgo, de modo que si el tiempo se agota lo no ejecutado sea siempre lo de menor riesgo) y la asignacion de personas (los riesgos criticos los ejecuta el tester con mayor experiencia y se revisan en pares). Los riesgos R-01, R-04 y R-09 concentran aproximadamente el 50% del esfuerzo planificado.
Niveles de prueba	Integracion (componente con componente y con base de datos) y Sistema (extremo a extremo por canal), mas una participacion acotada en Aceptacion. Se omite el nivel de Componente como responsabilidad de QA porque corresponde al equipo de desarrollo y ya existe una suite de 13 pruebas unitarias que QA adopta como linea base de regresion en lugar de duplicar.
Tipos de prueba	Funcionales (verificacion de reglas de negocio financieras), de Seguridad funcional (autenticacion, autorizacion vertical y horizontal), de Integracion de interfaces (contratos REST y canal ACH), de Regresion (proteccion del nucleo ante cambios) y de Usabilidad acotada (consistencia y responsive). Se excluye rendimiento por restriccion de ambiente, segun se justifica en el alcance.
Tecnicas de diseno	Caja negra: particion de equivalencia (estados de cuenta, tipos de cuenta, roles), analisis de valores limite (montos frente a saldo minimo, saldo disponible y limite diario: valor-0.01, valor exacto y valor+0.01), tabla de decision (combinacion de estado de cliente, estado de cuenta, saldo y limite en la transferencia) y transicion de estados (ciclo de vida de la sesion de caja y de la transferencia ACH). Caja blanca: cobertura de decisiones sobre las condiciones de los stored procedures, viable porque el codigo SQL esta versionado. Basada en experiencia: exploratoria con cartas de prueba y conjeturas de error sobre los modulos sin especificacion.
Pruebas manuales	Constituyen el grueso de esta entrega. Se aplican a los flujos de negocio de extremo a extremo, a la verificacion de mensajes al usuario y a la exploracion de los modulos sin especificacion formal. Se eligen porque la base de prueba es inestable (requerimientos por definir) y automatizar contra un comportamiento esperado que aun puede cambiar generaria retrabajo mayor que el beneficio.
Automatizacion	Se automatiza de forma selectiva donde el retorno es claro y el comportamiento esperado es estable: (1) la matriz de control de acceso, por ser repetitiva sobre 84 permisos y tres perfiles, inviable manualmente; (2) las pruebas de idempotencia ACH, que requieren envios concurrentes imposibles de coordinar a mano; y (3) la extension del smoke funcional ya existente para cubrir deposito, retiro y transferencia. Se reutiliza la infraestructura del proyecto (xUnit y el script Node de smoke) en lugar de

Elemento	Definicion y justificacion
	introducir herramientas nuevas, para no consumir tiempo del Sprint en configuracion.
Regresion	Suite de regresion en dos niveles: la suite completa (13 pruebas unitarias mas el smoke funcional) se ejecuta de forma automatica en cada integracion a la rama principal; un subconjunto priorizado de pruebas de sistema sobre las tres operaciones que mueven dinero se ejecuta de forma manual antes de cada cierre de ciclo. Todo defecto corregido de severidad alta o critica incorpora su caso de prueba a la suite de regresion automatizada.
Priorizacion	Orden de ejecucion descendente por nivel de riesgo, con dos criterios de desempate: primero los requerimientos con defectos ya detectados en el analisis (REQ-06, REQ-12, REQ-17), porque confirmarlos de forma temprana da al equipo de desarrollo el maximo tiempo de reaccion; y despues los requerimientos con dependencias externas (REQ-18), porque su resolucion puede requerir coordinacion con terceros.

8.2 Trazabilidad entre riesgo y decision de estrategia

La siguiente tabla hace explicito el vinculo entre cada riesgo relevante y la decision concreta de estrategia que lo mitiga. Es la evidencia de que la estrategia se derivo de los riesgos y no se definio de forma independiente.

Riesgo	Decision de estrategia derivada	Tecnica aplicada
R-01 (Critico)	Incorporacion de la seguridad funcional como tipo de prueba de prioridad critica y automatizacion de la matriz de control de acceso sobre los 84 permisos.	Matriz de control de acceso automatizada; particion de equivalencia por perfil
R-04 (Critico)	Diseno de casos comparativos que ejecutan la misma operacion en los tres canales y contrastan el resultado, en lugar de probar cada canal de forma aislada.	Tabla de decision; analisis de valores limite
R-09 (Critico)	Priorizacion temprana del canal ACH saliente y escalamiento previo de la definicion del manejo de fallos (H-06) por ser condicion de verificabilidad.	Transicion de estados; pruebas negativas de integracion
R-03 (Alto)	Verificacion conjunta de saldo y asiento contable tras cada transaccion, en lugar de verificar unicamente el saldo resultante.	Valores limite; verificacion de consistencia entre esquemas
R-10 (Medio)	Automatizacion de los envios duplicados concurrentes, imposibles de coordinar de forma manual con la precision necesaria.	Pruebas de concurrencia acotada
R-02 (Alto)	Incorporacion de casos de enumeracion de usuarios no previstos inicialmente, derivados del hallazgo H-08.	Conjetura de errores; particion de equivalencia
R-11 (Alto)	Registro documentado de cada supuesto asumido en el diseno de cada caso, para acotar el efecto de la ausencia de especificacion formal.	Pruebas exploratorias con cartas de prueba
R-15 (Medio)	Incorporacion de la carga verificada de datos semilla como criterio de entrada bloqueante.	Lista de verificacion de precondiciones

9. Niveles y tipos de prueba

9.1 Formato 8 - Seleccion justificada

No se seleccionan todos los niveles ni todos los tipos. Cada decision de inclusion o exclusion responde al perfil de riesgo del sistema, a las restricciones del ambiente y a la disponibilidad de recursos declarada en la seccion 11.

Nivel / Tipo	Aplica	Justificacion	Prioridad
Nivel: Componente (unitario)	Parcialmente	Es responsabilidad del equipo de desarrollo, no de QA. Sin embargo, QA adopta la suite existente de 13 pruebas unitarias (verificada: 13/13 exitosas) como linea base de regresion y exige su ampliacion hacia deposito, retiro y transferencia como criterio de salida. Duplicar ese nivel desde QA no agregaria valor.	Media
Nivel: Integracion	Si	Es el nivel de mayor retorno en este sistema por su arquitectura distribuida: la logica de negocio vive en stored procedures invocados desde servicios C#, y la configuracion de los bancos ACH vive en MongoDB	Critica

Nivel / Tipo	Aplica	Justificacion	Prioridad
		mientras las transacciones viven en PostgreSQL. La mayoria de los defectos previsibles estan en las costuras entre esos componentes, no dentro de ellos.	
Nivel: Sistema	Si	Es el unico nivel donde se puede verificar la coherencia de una regla de negocio a traves de los tres canales que mueven dinero, que es precisamente donde el analisis ya detecto divergencias (R-04). Concentra la verificacion de los flujos de negocio completos.	Critica
Nivel: Aceptacion	Parcialmente	Se ejecuta una aceptacion operativa acotada sobre los flujos de ventanilla y portal, con participacion del catedratico en el rol de Product Owner. No se realiza aceptacion de usuario formal porque no existen criterios de aceptacion aprobados contra los cuales el usuario pueda dar conformidad.	Media
Tipo: Funcional	Si	Es el tipo dominante porque el valor del sistema reside en aplicar correctamente reglas financieras. Concentra la verificacion de saldo minimo, saldo disponible, limite diario, estados de cuenta y cliente, e idempotencia ACH.	Critica
Tipo: Seguridad (funcional)	Si	Justificado por la naturaleza del sistema y por evidencia concreta: ya se confirmo un endpoint sin control de acceso que expone credenciales de terceros. Cubre autorizacion vertical (perfil sin permiso), horizontal (cliente accediendo a datos de otro cliente) y robustez del flujo de autenticacion. No incluye seguridad ofensiva, excluida del alcance.	Critica
Tipo: Integracion de interfaces (API)	Si	El canal ACH intercambia dinero con sistemas de terceros mediante contratos JSON configurables por banco. La verificacion del contrato (campos, codigos HTTP, manejo de error) es la unica forma de anticipar fallos que solo se manifestarian en produccion con un socio real.	Critica
Tipo: Regresion	Si	El repositorio muestra 79 commits en menos de dos meses sobre modulos que comparten el nucleo transaccional, con cambios recientes en ACH y en la interfaz. Esa frecuencia de cambio sobre codigo que mueve dinero hace obligatoria una red de regresion.	Alta
Tipo: Usabilidad	Parcialmente	Se acota a verificar consistencia de mensajes, comportamiento responsive en 390px y funcionamiento del modo oscuro, funcionalidad incorporada recientemente. No se realizan pruebas formales con usuarios ni evaluacion de accesibilidad por ausencia de criterios de referencia y de perfil especializado.	Baja
Tipo: Rendimiento	No	Se excluye porque el ambiente de QA comparte la instancia de base de datos remota con desarrollo: generar carga afectaria a otros equipos y los resultados no serian representativos de produccion. Ademas no existen requerimientos no funcionales cuantificados (BT-13) contra los cuales comparar, por lo que ninguna medicion tendria criterio de aprobacion. Se sustituye por pruebas de concurrencia acotada sobre la transferencia y la idempotencia ACH.	Baja
Tipo: Portabilidad / Compatibilidad	No	El sistema es de uso interno sobre un parque de equipos estandarizado. Se verifica unicamente en Chrome y Edge en sus versiones vigentes. Una matriz extendida de navegadores consumiria esfuerzo sin reducir riesgo relevante.	Baja

10. Criterios de entrada y de salida

Todos los criterios se expresan mediante una condicion verificable y un responsable identificado. Se evitaron de forma deliberada las formulaciones no medibles: un criterio como 'el sistema debe funcionar correctamente' no permite decidir nada y termina resolviendose por presion de calendario en lugar de por evidencia.

10.1 Formato 9a - Criterios de entrada

Criterio	Condicion verificable	Responsable
Ambiente de pruebas operativo	Los cuatro servicios responden correctamente: frontend HTTP 200 en el puerto 3000, InternalAPI HTTP 200 en /api/ping, PublicAPI responde en	Lider QA

Criterio	Condicion verificable	Responsable
	/swagger y MongoDB acepta conexiones. Verificable con el script dev-smoke-check.sh.	
Build desplegado e identificado	Existe una version etiquetada con su identificador de commit desplegada en el ambiente de QA, y el pipeline de integracion continua finalizo sin errores en esa version.	Equipo de Desarrollo
Datos de prueba cargados	Los scripts semilla estan ejecutados y verificados: al menos 1 usuario administrador, 3 clientes en estados distintos, 6 cuentas (3 AHORRO y 3 MONETARIA con saldos diferenciados), el plan de cuentas contables con los codigos 1101 y 2101 activos, y 2 bancos ACH configurados en MongoDB. Condicion no satisfecha al momento de esta planificacion.	Analista QA
Suite de regresion en verde	Las 13 pruebas unitarias existentes se ejecutan con 13 exitosas y 0 fallidas mediante dotnet test. Verificado el 15-09-2026.	Analista QA
Base de prueba revisada y hallazgos escalados	Los 24 requerimientos identificados cuentan con revision formal registrada (Formato 4) y los hallazgos de severidad critica y alta estan comunicados por escrito al Product Owner con acuse de recibo.	Lider QA
Bloqueantes de especificacion resueltos	Los hallazgos H-02 (umbral de bloqueo), H-07 (comportamiento ante descuadre de caja) y H-06 (manejo de fallo ACH) cuentan con definicion escrita del Product Owner, por ser los que impiden establecer un resultado esperado objetivo.	Product Owner
Casos de prueba disenados y revisados	El 100% de los requerimientos de prioridad Critica y Alta cuenta con casos de prueba disenados, y esos casos fueron revisados por un segundo integrante del equipo (revision por pares registrada).	Lider QA
Herramienta de gestion operativa	El repositorio de casos de prueba y el registro de defectos estan disponibles, con todos los integrantes del equipo con acceso de escritura confirmado.	Lider QA

Estado actual de los criterios de entrada

Al cierre de esta planificacion, tres criterios NO se cumplen: los datos de prueba no estan cargados (hallazgo H-15, verificado por observacion directa del ambiente), las definiciones de negocio bloqueantes siguen pendientes (H-02, H-06 y H-07) y los casos de prueba aun no estan disenados por depender de esas definiciones. En consecuencia, la fase de ejecucion no puede iniciarse en este momento.

10.2 Formato 9b - Criterios de salida

Criterio	Metrica o condicion verificable	Responsable
Cobertura de ejecucion sobre requerimientos criticos	100% de los casos de prueba asociados a requerimientos de prioridad Critica ejecutados (ninguno en estado No Ejecutado o Bloqueado).	Lider QA
Cobertura de ejecucion global	Igual o mayor al 90% de los casos de prueba disenados para el alcance In-Scope, ejecutados al menos una vez.	Analista QA
Tasa de exito en requerimientos criticos	Igual o mayor al 95% de casos aprobados en los requerimientos de prioridad Critica.	Lider QA
Defectos criticos abiertos	Cero defectos de severidad Critica en estado abierto, en analisis o pendientes de reprueba.	Lider QA
Defectos altos abiertos	Como maximo 2 defectos de severidad Alta abiertos, y unicamente si cuentan con solucion temporal documentada y aceptacion formal por escrito del Product Owner.	Product Owner
Defectos medios y bajos	Como maximo 8 defectos de severidad Media o Baja abiertos, todos registrados, priorizados y asignados a una entrega futura.	Lider QA
Reprueba de correcciones	100% de los defectos corregidos cuentan con reprueba ejecutada y resultado registrado; ninguno queda en estado Corregido sin verificar.	Analista QA
Regresion sin degradacion	La suite de regresion automatizada se ejecuta en verde (0 fallos) sobre la version candidata, incluyendo los casos incorporados a partir de los defectos corregidos durante el ciclo.	Analista QA
Cobertura de la matriz de	100% de los endpoints del alcance In-Scope verificados en los tres escenarios de acceso (sin token, con token sin permiso, con token y	Tester de Seguridad

Criterio	Metrica o condicion verificable	Responsable
control de acceso	permiso), sin ningun endpoint que responda 200 sin autenticacion.	
Consistencia de reglas entre canales	Las reglas de saldo minimo, saldo disponible y limite de retiro diario producen el mismo resultado en los tres canales para el mismo conjunto de datos de entrada, o bien la diferencia esta documentada y aceptada formalmente como regla de negocio.	Product Owner
Riesgos residuales evaluados	Todos los riesgos de nivel Critico y Alto cuentan con evidencia de mitigacion (casos ejecutados) o con aceptacion formal del riesgo residual por parte del Product Owner.	Lider QA
Documentacion de cierre entregada	Informe de cierre de pruebas entregado, con metricas de cobertura, densidad de defectos por modulo, riesgos residuales y recomendacion explicita de liberar o no liberar.	Lider QA

11. Recursos

11.1 Formato 10 - Recursos del proyecto de pruebas

Recurso	Descripcion	Responsable	Disponibilidad
Lider de QA	1 integrante. Define la estrategia, aprueba los criterios de entrada y salida, gestiona la comunicacion de hallazgos con el Product Owner y consolida el informe de cierre.	Integrante 1	Tiempo parcial durante todo el ciclo
Analista de Pruebas	1 integrante. Analiza la base de prueba, disena los casos y las condiciones de prueba, prepara y mantiene los datos de prueba.	Integrante 2	Tiempo parcial durante todo el ciclo
Tester funcional	1 integrante. Ejecuta las pruebas de ventanilla, portal y caja, registra los defectos y realiza las repruebas.	Integrante 3	Tiempo completo en la fase de ejecucion
Tester de seguridad e integracion	1 integrante. Ejecuta la matriz de control de acceso, las pruebas de autorizacion horizontal y las pruebas del canal ACH.	Integrante 4	Tiempo completo en la fase de ejecucion
Ambiente de QA (contenedores)	Docker Compose con cuatro servicios: frontend (puerto 3000), InternalAPI (5141), PublicAPI (5254) y MongoDB (27017). Levantado y verificado el 15-09-2026.	Lider QA	Disponible - verificado
Base de datos transaccional	PostgreSQL remoto (Supabase) con los esquemas del sistema. RESTRICCION: es compartida con el equipo de desarrollo, sin aislamiento para QA.	Equipo de Desarrollo	Disponible con restriccion (R-14)
Base de datos de configuracion ACH	MongoDB en contenedor local con la coleccion banks_configurations. Actualmente vacia; requiere ejecutar el script semilla 011_mongo_ach_seed.js.	Analista QA	Disponible - requiere carga de datos
Suite de pruebas automatizadas	xUnit sobre .NET 10 (13 pruebas) mas el script de smoke funcional en Node.js. Se ejecutan con dotnet test y node functional-smoke.mjs.	Analista QA	Disponible - verificado 13/13
Herramienta de prueba de APIs	Swagger UI incorporado en ambas APIs, mas cliente HTTP de linea de comandos para las pruebas de control de acceso. Se evita introducir herramientas nuevas para no consumir tiempo del Sprint en configuracion.	Tester de seguridad	Disponible
Herramienta de gestion de pruebas y defectos	Repositorio Git del proyecto con los documentos de QA y el tablero de incidencias asociado, por ser la infraestructura que el equipo ya utiliza.	Lider QA	Disponible
Scripts de datos de prueba	Scripts SQL versionados en Backend/database (seeds y scripts de demo) mas el script semilla de MongoDB.	Analista QA	Disponible - pendiente de ejecucion
Equipos de trabajo	4 estaciones de trabajo con Docker Desktop, .NET SDK 10, Node.js y navegadores Chrome y Edge.	Cada integrante	Disponible
Tiempo asignado	4 semanas de calendario (del 16-09-2026 al 13-10-2026), con dedicacion parcial compatible con la carga academica de los integrantes.	Lider QA	Restriccion del proyecto

12. Roles y responsabilidades

Se aplica el modelo RACI: R (Responsible) ejecuta la actividad; A (Accountable) responde por el resultado y es unico por actividad; C (Consulted) aporta informacion antes de la decision; I (Informed) recibe el resultado. La notacion A/R indica que la misma persona ejecuta y responde.

12.1 Formato 11 - Matriz RACI

Actividad	Analista QA	Lider QA	Desarrollo	PO / Cliente
Definir la estrategia de pruebas	C	A/R	C	I
Analizar y revisar la base de prueba	R	A	C	C
Identificar y valorar los riesgos	R	A	C	C
Aclarar requerimientos ambiguos o incompletos	C	R	C	A
Definir los criterios de entrada y salida	C	A/R	C	C
Disenar los casos y condiciones de prueba	A/R	C	I	I
Preparar y mantener los datos de prueba	A/R	C	C	I
Preparar y mantener el ambiente de pruebas	C	A	R	I
Ejecutar las pruebas	R	A	I	I
Registrar y clasificar los defectos	R	A	C	I
Corregir los defectos	I	C	A/R	I
Reprobar las correcciones	R	A	C	I
Decidir sobre defectos aceptados sin corregir	C	R	C	A
Ejecutar y mantener la suite de regresion	R	A	C	I
Evaluar los criterios de salida	C	A/R	I	C
Aceptar los riesgos residuales	C	R	C	A
Elaborar el informe de cierre de pruebas	C	A/R	I	I
Autorizar la liberacion a produccion	I	C	C	A/R

Dos asignaciones merecen explicacion. La aclaracion de requerimientos ambiguos tiene al Product Owner como Accountable y no a QA, porque QA puede detectar la ambiguedad pero no puede resolverla: la decision de negocio no le corresponde. Y la aceptacion de riesgos residuales tambien recae en el Product Owner, porque asumir un riesgo no cubierto es una decision de negocio y no una decision tecnica; el rol de QA es hacer visible el riesgo, no decidir si se acepta.

13. Ambiente de pruebas

13.1 Formato 12 - Configuracion del ambiente

Elemento	Configuracion	Estado	Responsable
Servidor de aplicacion frontend	Contenedor Docker con Node.js y Vite en modo desarrollo con recarga en caliente. Expuesto en http://localhost:3000.	Operativo - verificado HTTP 200	Lider QA
Servidor de API interna	Contenedor Docker con ASP.NET Core 10 ejecutando dotnet watch. Expuesto en http://localhost:5141, con Swagger habilitado.	Operativo - verificado /api/ping HTTP 200	Equipo de Desarrollo
Servidor de API publica	Contenedor Docker con ASP.NET Core 10. Expuesto en http://localhost:5254, publica los endpoints /api/external/ach y /api/external/auth.	Operativo - Swagger accesible	Equipo de Desarrollo
Base de datos	PostgreSQL alojado en Supabase (region sa-east-1), accedido por	Operativo -	Equipo de

Elemento	Configuracion	Estado	Responsable
transaccional	cadena de conexion con pooler. Contiene los esquemas seguridad, clientes, cuentas, transacciones, caja, contabilidad, auditoria y ach.	compartido con desarrollo (R-14)	Desarrollo
Base de datos de configuracion	MongoDB 7 en contenedor local, base banco_ach, coleccion banks_configurations.	Operativo pero SIN DATOS - requiere semilla	Analista QA
Navegadores	Google Chrome y Microsoft Edge en sus versiones vigentes, resoluciones de 1440x900 para escritorio y 390x844 para la verificacion responsive.	Disponible	Cada tester
Autenticacion del ambiente	JWT con expiracion de 1 hora y refresh token de 7 dias. Umbral de intentos fallidos configurado en 5 y token de recuperacion con vigencia de 2 horas.	Configurado - difiere del valor por defecto del codigo (H-02)	Lider QA
Orquestacion	Docker Compose con cuatro servicios y volumenes persistentes para dependencias. Levantado con docker compose up -d --build.	Operativo - verificado 15-09-2026	Lider QA
Integracion continua	GitHub Actions: construye los contenedores, levanta una instancia PostgreSQL temporal y ejecuta el smoke funcional aislado.	Operativo	Equipo de Desarrollo

Verificacion del ambiente realizada el 15-09-2026

El equipo levanto el ambiente completo mediante Docker Compose y confirmo que los cuatro servicios responden correctamente. Sobre ese ambiente se ejecutaron las verificaciones empiricas citadas en los hallazgos H-05, H-02 y H-15, y se capturaron las 21 evidencias del Anexo A. La suite de pruebas unitarias se ejecuto con resultado de 13 exitosas y 0 fallidas.

14. Datos de prueba

14.1 Formato 13 - Conjuntos de datos requeridos

ID	Tipo	Descripcion	Fuente	Sensibilidad	Disponibilidad
DT-01	Valido	Usuario administrador con todos los permisos, para verificar los flujos completos y servir de control en las pruebas de autorizacion.	Script seed seguridad_admin_seed.sql	Media - credencial de ambiente no productivo	**Disponible**
DT-02	Valido	Usuario cajero con empleado activo asociado y permisos de deposito, retiro y transferencia, sin permisos de seguridad.	Creacion manual desde el modulo de seguridad	Media	Por preparar
DT-03	Valido	Usuario cliente con acceso al portal Mi Banco, vinculado a un cliente en estado ACTIVO con dos cuentas propias.	Script de demostracion seed_crm_bpm_demo.sql	Media	Por preparar
DT-04	Valido	Usuario de banco externo con rol BANCO_EXTERNO para el canal ACH publico.	Script 013_external_public_ach.sql	Alta - credencial de integracion	**Disponible**
DT-05	Valido	Cuenta de tipo AHORRO con saldo Q10,000.00, saldo minimo Q100.00 y limite de retiro diario Q5,000.00. Es el juego de datos principal para las pruebas de valores limite.	Procedimiento de apertura de cuenta	Baja - datos ficticios	Por preparar
DT-06	Valido	Cuenta de tipo MONETARIA con saldo Q10,000.00, saldo minimo Q0.00 y sin limite de retiro diario. Permite contrastar el tratamiento diferenciado por tipo de cuenta (R-04).	Procedimiento de apertura de cuenta	Baja - datos ficticios	Por preparar
DT-07	Limite	Conjunto de montos calculados alrededor de cada frontera: saldo disponible exacto, saldo disponible menos un centavo y mas un centavo; saldo minimo exacto y su entorno; limite diario exacto y su entorno; y monto cero.	Calculado por el Analista QA	Baja	Por preparar

ID	Tipo	Descripcion	Fuente	Sensibilidad	Disponibilidad
DT-08	Invalido	Montos negativos, cero, con mas de dos decimales, con separadores de miles y en formato de texto, para verificar la robustez de la validacion de entrada.	Calculado por el Analista QA	Baja	Por preparar
DT-09	Invalido	Cuentas en estado BLOQUEADA y CERRADA, y cliente en estado INACTIVO, para verificar el rechazo por estado en los tres canales.	Modificacion controlada de datos semilla	Baja	Por preparar
DT-10	Valido	Dos configuraciones de banco ACH en MongoDB con plantillas JSON distintas, una activa y otra inactiva, para verificar el comportamiento diferenciado.	Script 011_mongo_ach_seed.js	Alta - contiene credenciales de integracion	Por preparar
DT-11	Limite	Peticiones ACH entrantes con codigo de confirmacion repetido, enviadas de forma secuencial y concurrente, para verificar la idempotencia (R-10).	Construido por el Tester de seguridad	Baja	Por preparar
DT-12	Invalido	Peticiones ACH con moneda distinta de GTQ/Q, con tipo distinto de ENTRANTE y con campos obligatorios ausentes, para verificar las validaciones del contrato publico.	Construido por el Tester de seguridad	Baja	Por preparar
DT-13	Invalido	Contrasenas que incumplen la politica: de 7 caracteres, sin mayuscula, sin digito, y contrasenas ya presentes en el historial del usuario.	Calculado por el Analista QA	Baja	Por preparar
DT-14	Valido	Plan de cuentas contables con los codigos 1101 y 2101 en estado activo. Es precondicion obligatoria: sin estos registros toda transaccion falla (REQ-21).	Script 008_catalogs_seed.sql	Baja	Por verificar

14.2 Tratamiento y proteccion de los datos

Ningun conjunto de datos utiliza informacion personal real de clientes. Los nombres, documentos de identidad y direcciones se generan de forma ficticia. Las credenciales de los usuarios de prueba son exclusivas del ambiente de QA y no se reutilizan en produccion. Los datos marcados con sensibilidad Alta corresponden a credenciales de integracion con bancos socios y no deben incluirse en evidencias, capturas de pantalla ni reportes distribuidos fuera del equipo; esta restriccion adquiere especial relevancia por el hallazgo H-05, que confirma su exposicion actual.

15. Cronograma

15.1 Formato 14 - Planificacion de actividades

Actividad	Inicio	Fin	Responsable	Dependencia	Estado
Analisis de la base de prueba y revision de requerimientos	16-09-2026	22-09-2026	Analista QA	Acceso al repositorio y a la documentacion disponible	Completado
Identificacion y valoracion de riesgos	18-09-2026	23-09-2026	Lider QA	Analisis de la base de prueba	Completado
Elaboracion del Master Test Plan	22-09-2026	26-09-2026	Lider QA	Analisis de riesgos concluido	Completado
Escalamiento de hallazgos y espera de definiciones del PO	26-09-2026	30-09-2026	Lider QA	Master Test Plan aprobado	En curso
Preparacion del ambiente y carga de datos de prueba	29-09-2026	02-10-2026	Analista QA	Scripts semilla disponibles y ambiente levantado	Pendiente
Diseno de casos de prueba de requerimientos criticos	30-09-2026	06-10-2026	Analista QA	Definiciones del PO sobre H-02, H-06 y H-07	Pendiente
Diseno de casos de prueba de requerimientos altos y medios	05-10-2026	08-10-2026	Analista QA	Diseno de casos criticos concluido	Pendiente
Revision por pares de los casos disenados	07-10-2026	09-10-2026	Lider QA	Casos de prueba disenados	Pendiente
Ejecucion - Ciclo 1 (seguridad y control de acceso)	09-10-2026	13-10-2026	Tester de seguridad	Criterios de entrada satisfechos	Pendiente

Actividad	Inicio	Fin	Responsable	Dependencia	Estado
Ejecucion - Ciclo 1 (ventanilla, caja y portal)	09-10-2026	15-10-2026	Tester funcional	Criterios de entrada satisfechos y datos cargados	Pendiente
Ejecucion - Ciclo 1 (canal ACH)	13-10-2026	16-10-2026	Tester de seguridad	Bancos ACH configurados en MongoDB	Pendiente
Registro de defectos y correccion por desarrollo	10-10-2026	20-10-2026	Equipo de Desarrollo	Defectos reportados durante el ciclo 1	Pendiente
Ejecucion - Ciclo 2 (reprueba de correcciones)	17-10-2026	22-10-2026	Tester funcional	Defectos corregidos y desplegados	Pendiente
Ejecucion de la suite de regresion	21-10-2026	23-10-2026	Analista QA	Repruebas concluidas	Pendiente
Evaluacion de criterios de salida e informe de cierre	23-10-2026	24-10-2026	Lider QA	Regresion en verde	Pendiente

La ruta critica del cronograma no es tecnica sino de informacion: el diseno de los casos de prueba de los requerimientos criticos no puede iniciar hasta que el Product Owner resuelva las definiciones pendientes (H-02, H-06 y H-07). Por esa razon la actividad de escalamiento se programo antes de la fase de diseno y no en paralelo. Un retraso en esa respuesta desplaza de forma directa la fecha de cierre del ciclo completo.

16. Supuestos, restricciones y dependencias

16.1 Formato 15 - Registro consolidado

Categoria	Descripcion	Impacto sobre el proyecto de pruebas
Supuesto	El catedratico asume el rol de Product Owner y resolvera por escrito las definiciones de negocio que faltan (umbral de bloqueo, comportamiento ante descuadre de caja, manejo de fallos ACH).	Alto. Si las definiciones no llegan, tres requerimientos criticos no tendran resultado esperado objetivo y sus pruebas solo podran verificar consistencia interna, no correccion de negocio.
Supuesto	Los valores por defecto presentes en el codigo SQL (saldo minimo de Q100.00 y limite de retiro diario de Q5,000.00 para cuentas AHORRO) representan reglas de negocio correctas mientras no se indique lo contrario.	Medio. Si el negocio los desmiente, se invalidan los casos de valores limite disenados sobre esas fronteras y debera rehacerse el diseno correspondiente.
Supuesto	El codigo fuente versionado en la rama principal es la fuente de verdad del comportamiento esperado, en ausencia de especificacion formal.	Alto. Implica que QA solo puede detectar inconsistencias internas y defectos evidentes, no divergencias respecto de la necesidad real del negocio.
Supuesto	El equipo de desarrollo corregira los defectos criticos dentro del mismo ciclo en que se reportan.	Medio. Un retraso desplaza el ciclo de reprueba y compromete la fecha de cierre.
Supuesto	La instancia de base de datos remota se mantendra disponible durante toda la ventana de ejecucion.	Alto. Su indisponibilidad detiene por completo la ejecucion de pruebas (R-14).
Restriccion	El ambiente de QA no esta aislado: comparte la instancia PostgreSQL remota con el equipo de desarrollo.	Alto. Impide pruebas de rendimiento, hace que los resultados dependan de datos que terceros pueden modificar durante la ejecucion, y obliga a verificar el estado de los datos antes de cada caso.
Restriccion	El equipo dispone de 4 semanas de calendario con dedicacion parcial, compatible con la carga academica de sus integrantes.	Alto. Obliga a una priorizacion estricta por riesgo y a excluir modulos completos del alcance, aceptando el riesgo residual correspondiente.
Restriccion	No se dispone de licencias de herramientas comerciales de gestion de pruebas, automatizacion ni analisis de seguridad.	Medio. Obliga a reutilizar la infraestructura existente del proyecto (xUnit, script de smoke, Swagger) y a excluir las pruebas de penetracion del alcance.
Restriccion	No existe un ambiente equivalente a produccion en dimensionamiento.	Medio. Los resultados de cualquier medicion de tiempos no serian extrapolables, lo que refuerza la exclusion de las pruebas de rendimiento.
Restriccion	Ningun integrante del equipo posee certificacion ni experiencia formal en seguridad ofensiva.	Medio. Acota las pruebas de seguridad a la verificacion funcional de los controles de acceso.
Dependencia	Definiciones de negocio pendientes del Product Owner sobre los hallazgos H-02, H-06 y H-07.	Critico. Es la dependencia bloqueante de mayor impacto: condiciona el inicio del diseno de casos de los

Categoria	Descripcion	Impacto sobre el proyecto de pruebas
		requerimientos REQ-02, REQ-09 y REQ-18.
Dependencia	Correccion por parte del equipo de desarrollo del defecto de control de acceso en el modulo ACH (H-05).	Critico. Mientras persista, cualquier prueba sobre ese modulo se ejecuta sobre una version que ya se sabe defectuosa, y el riesgo R-01 permanece sin mitigar.
Dependencia	Disponibilidad de los bancos externos o de un simulador para las pruebas de ACH saliente.	Alto. Sin un extremo receptor no es posible verificar el flujo completo de envio; obliga a simular respuestas y deja el escenario real sin cobertura.
Dependencia	Ejecucion de los scripts semilla de PostgreSQL y MongoDB para disponer de datos de prueba.	Alto. Es condicion de entrada: hoy el ambiente no tiene datos suficientes para ejecutar ningun escenario de negocio (R-15).
Dependencia	Estabilidad de la rama principal durante la ventana de ejecucion.	Medio. Cambios no comunicados invalidarian resultados ya obtenidos y obligarian a repetir pruebas.

17. Problemas identificados en la base de prueba

Los quince hallazgos siguientes son el resultado directo del analisis documentado en la seccion 5. Ninguno es una observacion generica: cada uno identifica el requerimiento afectado, describe el problema de forma especifica, evalua su impacto concreto sobre la actividad de pruebas y propone una accion. Los hallazgos marcados como verificados corresponden a comprobaciones ejecutadas sobre el sistema real, cuya evidencia se incluye en el Anexo A.

ID	Req. afectado	Problema detectado	Sever.	Impacto sobre las pruebas	Accion recomendada	Estado
H-01	Toda la base de prueba	No existen historias de usuario, criterios de aceptacion formales ni reglas de negocio validadas por el area usuaria. Cuatro de los trece artefactos de la base de prueba (BT-10, BT-11, BT-12 y BT-13) no existen, por lo que el equipo QA debe inferir el comportamiento esperado a partir del codigo fuente.	Critica	QA solo puede verificar consistencia interna, no correccion de negocio. Se pierde la capacidad de detectar el defecto mas costoso: que el sistema funcione correctamente pero haga algo distinto de lo que el negocio necesita. Genera riesgo de falsos negativos en todo el alcance.	Escalar al Product Owner la construccion de un backlog minimo con criterios de aceptacion para los 10 requerimientos de prioridad Critica. Mientras tanto, documentar de forma explicita cada supuesto asumido en el diseno de cada caso de prueba.	Abierto
H-02	REQ-02	El umbral de bloqueo por intentos fallidos tiene dos valores distintos y ninguno esta respaldado por un requerimiento: el codigo define 3 como valor por defecto y la configuracion del ambiente define 5. Evidencia: la interfaz muestra el mensaje 'Credenciales incorrectas. Intento 1 de 5'. Tampoco se define la duracion del bloqueo ni el procedimiento de desbloqueo.	Alta	Impide establecer un resultado esperado objetivo: el tester no puede determinar si bloquear al tercer o al quinto intento constituye un aprobado o un fallo. Bloquea el diseno de los casos de REQ-02 y el comportamiento cambia segun el ambiente donde se ejecute la prueba.	Solicitar al Product Owner la definicion formal del umbral, la duracion del bloqueo y el mecanismo de desbloqueo. Una vez definido, alinear el valor por defecto del codigo con el de la configuracion para eliminar la ambiguedad.	Abierto
H-03	REQ-11, REQ-12, REQ-16	La regla de limite de retiro diario esta implementada de tres maneras distintas segun el canal. Verificado por analisis estatico: el procedimiento sp_retiro la aplica unicamente a cuentas de tipo AHORRO; el procedimiento sp_transferir_fondos no la aplica en absoluto (cero referencias a limite_retiro_diario y a monto_retirado_hoy) y ademas no acumula el monto transferido; y el servicio del portal la aplica en codigo C# a cualquier tipo de cuenta y si acumula. En consecuencia, un cliente puede evadir por completo el limite diario ejecutando transferencias en ventanilla en lugar de retiros.	Alta	Obliga a duplicar los casos de prueba por canal en lugar de verificar una unica implementacion, lo que incrementa el esfuerzo de forma significativa. Ademas impide definir un resultado esperado unico para la regla, porque no se sabe cual de los tres comportamientos es el correcto.	Escalar al negocio para determinar cual es la regla valida y si la exencion de las cuentas MONETARIA es deliberada. Recomendar al equipo de desarrollo unificar la regla en un unico punto reutilizado por los tres canales. Es el insumo principal del riesgo R-04.	Abierto
H-04	REQ-01	El contrato del endpoint de autenticacion expone tres campos (Email, Password y Username) y deriva internamente un identificador, sin documentar cual es obligatorio. Verificado: una peticion con el campo 'username' responde HTTP 200, mientras una peticion con el campo 'identificador' responde HTTP 400, pese a que la interfaz rotula ese campo como 'Usuario o correo'.	Media	Impide disenar los casos negativos de campo obligatorio ausente, porque no se sabe cual campo lo es. Afecta tambien a la automatizacion, que debe construirse contra un contrato observado y no especificado, con riesgo de romperse ante cualquier cambio.	Solicitar la definicion formal del contrato de login y su documentacion en Swagger, de modo equivalente a la que ya existe para el canal ACH publico.	Abierto
H-05	REQ-06, REQ-17	Los controladores de bancos ACH y de transferencias ACH internas no declaran ningun atributo de autorizacion, y la aplicacion no define una politica de autorizacion por defecto. Verificado mediante peticion directa: GET /api/ach/bancos responde HTTP 200 sin token de autenticacion, mientras GET /api/clientes responde HTTP 401. Ademas, la respuesta de ese endpoint incluye el campo de contrasena de integracion de cada banco socio en texto plano.	Critica	Invalida el supuesto de que el control de acceso es uniforme, por lo que la matriz de control de acceso debe recorrer exhaustivamente todos los endpoints en lugar de verificar una muestra. Cualquier prueba sobre el modulo ACH se ejecuta sobre una version que ya se sabe defectuosa.	Reportar como defecto de seguridad critico antes del inicio de la ejecucion. Recomendar la declaracion de una politica de autorizacion por defecto que exija usuario autenticado, de modo que la omision de un atributo no derive en un endpoint publico, y el enmascaramiento de las credenciales en la respuesta.	Abierto
H-06	REQ-18	No existe especificacion del comportamiento del sistema ante la indisponibilidad del banco externo destino en una transferencia ACH saliente: no se define politica de reintentos, tiempo maximo de espera, estado final de la transferencia ni procedimiento de conciliacion o reverso de los fondos debitados.	Critica	El requerimiento con mayor riesgo economico del sistema es simultaneamente el menos verificable. No es posible disenar los casos de prueba de la ruta de fallo, que es justamente donde se materializa el riesgo R-09 de fondos debitados sin acreditar en destino.	Solicitar al Product Owner y al area de arquitectura la especificacion del manejo de fallos de integracion. Hasta obtenerla, acotar las pruebas al camino exitoso y dejar constancia formal del riesgo residual no cubierto.	Abierto
H-07	REQ-09	No se define el comportamiento esperado ante un descuadre entre el	Alta	Sin esa definicion no existe resultado esperado	Escalar al area de Operaciones. Es la definicion mas	Abierto

ID	Req. afectado	Problema detectado	Sever.	Impacto sobre las pruebas	Accion recomendada	Estado
		efectivo declarado en el cierre de caja y el efectivo esperado calculado por el sistema: no se especifica si el cierre debe bloquearse, permitirse con justificacion obligatoria o registrarse como diferencia para revision posterior.		objetivo para el escenario principal del modulo de caja, que es precisamente el de mayor valor para el negocio. Bloquea el diseno del conjunto de casos de cierre.	urgente del modulo de caja porque determina el resultado esperado de todo el conjunto de pruebas de cierre.	
H-08	REQ-02, REQ-01	El flujo de autenticacion revela informacion util para un atacante: el mensaje de error indica el numero de intento sobre el total permitido, y el sistema responde con codigos HTTP distintos segun el usuario no exista (401), este inactivo (403) o este bloqueado (423), lo que permite enumerar cuentas validas. Adicionalmente se observo una inconsistencia en la interfaz: el mensaje en linea muestra 'Credenciales incorrectas. Intento 1 de 5' mientras la notificacion emergente muestra 'Usuario o contrasena incorrectos' de forma simultanea.	Media	Requiere incorporar al alcance casos especificos de enumeracion de usuarios que no estaban previstos, y casos de verificacion de consistencia de mensajes. Afecta directamente la valoracion del riesgo R-02.	Recomendar mensajes genericos e indistinguibles entre si para todos los casos de fallo de autenticacion, y unificar el mensaje mostrado en la interfaz.	Abierto
H-09	REQ-23	El proyecto declara dependencias de terceros con vulnerabilidades conocidas y el proceso de construccion las reporta como advertencia sin bloquear el despliegue. Confirmado en la salida de compilacion: Snappier 1.0.0 y Microsoft.OpenApi 2.4.1 con severidad alta, y SharpCompress 0.30.1 con severidad moderada.	Media	Introduce en el alcance un riesgo de seguridad que no proviene del codigo propio y que las pruebas funcionales no pueden detectar. Obliga a incorporar la revision de dependencias como actividad recurrente y como criterio de salida.	Reportar al equipo de desarrollo para actualizacion de las dependencias afectadas y proponer una compuerta de calidad en el pipeline que impida el despliegue ante vulnerabilidades de severidad alta.	Abierto
H-10	REQ-10, REQ-11, REQ-12	No existe definicion de monto maximo por transaccion para las operaciones de ventanilla. Los procedimientos validan unicamente que el monto sea mayor que cero, sin tope superior, y no existe regla de umbral que exija autorizacion de un supervisor para operaciones de alto valor, control habitual en la practica bancaria.	Media	Impide disenar el caso de valor limite superior, que queda sin frontera definida. El tester no puede determinar si un deposito de un millon de quetzales constituye un comportamiento correcto o un defecto.	Consultar al negocio si deben existir topes por transaccion y umbrales de autorizacion. Mientras tanto, documentar la ausencia de tope como riesgo de negocio no cubierto.	Abierto
H-11	REQ-24, REQ-23	No existen requerimientos no funcionales cuantificados: no hay tiempos de respuesta objetivo, volumen esperado de transacciones, numero de usuarios concurrentes ni politica de retencion de bitacoras de auditoria.	Media	Impide definir criterios de salida medibles para rendimiento y disponibilidad, y sustenta la exclusion de las pruebas de rendimiento del alcance. Cualquier medicion careceria de criterio de aprobacion.	Solicitar al negocio la definicion de los niveles de servicio esperados, al menos para las tres operaciones que mueven dinero y para el canal ACH.	Abierto
H-12	REQ-10, REQ-11, REQ-12, REQ-16	La cobertura de pruebas automatizadas es minima y esta concentrada fuera del nucleo de mayor riesgo. Verificado mediante ejecucion: 13 pruebas unitarias, todas exitosas, que cubren unicamente la construccion del payload ACH y la autorizacion del banco externo. No existe ninguna prueba automatizada sobre deposito, retiro, transferencia interna, sesion de caja ni portal del cliente.	Media	La red de regresion disponible no protege las operaciones que mueven dinero, por lo que todo cambio sobre ellas exige reprueba manual completa. Incrementa el costo de cada ciclo de regresion y el riesgo de introducir defectos no detectados.	Adoptar las 13 pruebas existentes como linea base y exigir como criterio de salida la incorporacion de pruebas automatizadas para las tres operaciones transaccionales criticas.	Abierto
H-13	REQ-21	La generacion de asientos contables depende de la existencia previa de cuentas contables activas en el plan de cuentas (codigos 1101 y 2101). Si no existen, el procedimiento lanza una excepcion y la transaccion completa falla. Esta dependencia no esta documentada como precondicion en ningun requerimiento funcional.	Media	Un fallo de datos maestros se manifestaria como un defecto funcional del modulo de transacciones, induciendo a reportes de defecto incorrectos y a desperdicio de tiempo en analisis. Obliga a incorporar la verificacion del plan de cuentas a los criterios de entrada.	Documentar la dependencia como precondicion obligatoria del ambiente e incorporarla a la lista de verificacion de criterios de entrada.	Abierto
H-14	REQ-04	El endpoint de solicitud de recuperacion de contrasena devuelve el token de recuperacion en el cuerpo de la respuesta HTTP, sin que exista un requerimiento que defina el canal de entrega esperado (correo electronico u otro).	Media	No es verificable si el comportamiento constituye una decision de diseno deliberada para el ambiente academico o un defecto de seguridad. El tester no puede emitir un veredicto objetivo.	Consultar al Product Owner el canal de entrega esperado. Si la definicion indica entrega por correo, el comportamiento actual debe reclasificarse como defecto de severidad critica.	Abierto
H-15	Ambiente de pruebas	El ambiente levantado no contiene datos suficientes para ejecutar escenarios de negocio. Verificado por observacion directa: el tablero muestra la leyenda 'Sin datos disponibles', los saldos totales aparecen en Q0.00 y el modulo ACH reporta cero bancos configurados por estar vacia la coleccion de MongoDB.	Alta	Los criterios de entrada no se cumplen: ninguna prueba de negocio puede ejecutarse en el estado actual del ambiente. Es condicion bloqueante para el inicio de la fase de ejecucion.	Ejecutar los scripts semilla ya disponibles en el repositorio y verificar la carga antes de declarar satisfechos los criterios de entrada. El esfuerzo es bajo porque los scripts ya existen y estan versionados.	Abierto

17.1 Distribucion de los hallazgos

Severidad	Cant.	Hallazgos	Efecto sobre la planificacion
Critica	3	H-01, H-05, H-06	H-05 es un defecto de seguridad confirmado que debe corregirse antes de iniciar la ejecucion. H-01 y H-06 son ausencias de especificacion que limitan de forma estructural lo que las pruebas pueden demostrar.
Alta	4	H-02, H-03, H-07, H-15	Tres de ellos bloquean el diseno de casos por falta de resultado esperado objetivo. H-15 bloquea el inicio de la ejecucion por ausencia de datos.
Media	8	H-04, H-08, H-09, H-10, H-11, H-12, H-13, H-14	No bloquean el avance, pero amplian el alcance de las pruebas (casos adicionales de enumeracion, de dependencias y de precondiciones de datos maestros).

Los dos hallazgos verificados de forma empirica

H-05: se ejecuto una peticion GET a /api/ach/bancos sin token de autenticacion y el sistema respondio HTTP 200, mientras la misma prueba sobre /api/clientes respondio HTTP 401. La respuesta del primer endpoint incluye el campo de contrasena de integracion de los bancos socios. H-03: el analisis del codigo de los procedimientos almacenados confirmo que sp_transferir_fondos no contiene ninguna referencia a limite_retiro_diario ni a monto_retirado_hoy, mientras sp_retiro si las contiene, lo que permite evadir el limite diario transfiriendo en lugar de retirando.

18. Priorizacion de pruebas

El orden de ejecucion se deriva del nivel de riesgo calculado en la seccion 7, con dos criterios de desempate aplicados de forma explicita: se adelantan los requerimientos con defectos ya confirmados durante el analisis, porque confirmarlos de forma temprana da al equipo de desarrollo el maximo tiempo de reaccion; y se adelantan los requerimientos con dependencias externas, porque su resolucion puede requerir coordinacion con terceros y esa espera no debe comprometer el cierre.

Requerimiento	Riesgo asociado	Prioridad	Justificacion de la posicion asignada	Orden
REQ-06	R-01 (Critico - 25)	**Critica**	Es el unico requerimiento con un defecto de seguridad ya confirmado por evidencia directa y de impacto maximo. Se ejecuta primero porque su resultado condiciona la validez de todas las demas pruebas: si el control de acceso no es confiable, ninguna verificacion funcional posterior puede darse por buena.	1
REQ-17	R-01 (Critico - 25)	**Critica**	Comparte el riesgo maximo con REQ-06 y expone credenciales de bancos socios, lo que traslada el impacto fuera de la organizacion. Se ejecuta inmediatamente despues por pertenecer al mismo defecto raiz.	2
REQ-12	R-04 (Critico - 20)	**Critica**	Defecto de regla de negocio ya confirmado por analisis estatico, con probabilidad maxima de materializarse. Permite evadir un control antifraude y se ejecuta de forma temprana para dar al equipo de desarrollo el maximo tiempo de reaccion.	3
REQ-18	R-09 (Critico - 20)	**Critica**	Concentra el mayor riesgo economico del sistema (fondos que salen sin llegar a destino) y depende de terceros, por lo que su resolucion puede requerir coordinacion externa. Se adelanta para que el tiempo de coordinacion no comprometa el cierre.	4
REQ-11	R-03 (Alto-15), R-04 (Critico-20)	**Critica**	Es la operacion con mayor densidad de reglas de frontera (saldo disponible, saldo minimo y limite diario) y comparte con REQ-12 la inconsistencia de la regla de limite. Requiere el conjunto mas extenso de valores limite.	5
REQ-16	R-04 (Critico-20), R-05 (Medio-10)	**Critica**	Es el canal expuesto directamente al cliente final sin intermediacion, lo que eleva el riesgo de acceso horizontal, y contiene la tercera implementacion divergente de la regla de limite diario.	6
REQ-19	R-10 (Medio - 10)	**Critica**	La idempotencia es la unica barrera contra la doble acreditacion de fondos externos, de impacto economico maximo e irrecuperable. Se prioriza pese a su probabilidad baja por lo severo de la consecuencia.	7
REQ-10	R-03 (Alto - 15)	**Critica**	Mueve dinero y alimenta el registro contable. Se ubica despues del retiro porque tiene menos reglas de frontera y su ruta de fallo es menos critica: un deposito rechazado no genera perdida.	8
REQ-15	R-05 (Medio - 10)	**Critica**	Riesgo de violacion del secreto bancario por acceso horizontal. Prioridad critica por el impacto regulatorio, aunque la probabilidad es baja porque el filtrado por cliente esta implementado de forma explicita.	9
REQ-01	R-02 (Alto - 15)	**Alta**	Es la puerta de entrada al sistema completo. Se ubica en este punto y no antes porque su funcionamiento basico ya quedo verificado durante la preparacion del ambiente; lo que resta es la verificacion de casos negativos y de robustez.	10
REQ-02	R-02 (Alto - 15)	**Alta**	Control antifuerza bruta de alto valor, pero su ejecucion esta condicionada a que el Product Owner defina el umbral (H-02). Se programa despues de la fecha comprometida para esa definicion.	11
REQ-05	R-02 (Alto - 15)	**Alta**	La gestion de sesiones determina por cuanto tiempo una credencial comprometida sigue siendo util. Requerimiento completo y verificable, sin dependencias externas.	12
REQ-20	R-01 (Critico - 25)	**Alta**	Pertenece al riesgo maximo, pero se prioriza por debajo de los anteriores porque ya cuenta con cobertura de pruebas unitarias verificada, lo que reduce su riesgo residual.	13
REQ-08	R-06 (Alto - 12)	**Alta**	Es precondicion obligatoria de toda operacion de ventanilla: si falla, se bloquea la operacion completa de la sucursal. Se verifica antes que el cierre por ser su antecedente logico.	14
REQ-09	R-06 (Alto - 12)	**Alta**	Tiene impacto contable y de auditoria, pero su escenario principal esta bloqueado por la falta de definicion del comportamiento ante descuadre (H-07).	15
REQ-14	R-04 (Critico - 20)	**Alta**	Define los parametros financieros que gobiernan todas las transacciones posteriores de cada cuenta. Se ejecuta como parte de la preparacion de datos y se verifica de forma explicita.	16

Requerimiento	Riesgo asociado	Prioridad	Justificacion de la posicion asignada	Orden
REQ-21	R-03 (Alto - 15)	**Alta**	Un descuadre entre saldo y contabilidad es un hallazgo grave de auditoria. Se verifica de forma conjunta con las transacciones que generan los asientos, aprovechando la misma ejecucion.	17
REQ-07	R-07 (Medio - 8)	**Alta**	Requisito de trazabilidad regulatoria. Se verifica de forma transversal durante la ejecucion de los demas casos, comprobando que cada accion deje su registro correspondiente.	18
REQ-03	R-02 (Alto - 15)	**Media**	Regla de composicion clara y completamente verificable, con un conjunto de casos acotado y de bajo costo de ejecucion.	19
REQ-04	R-02 (Alto - 15)	**Media**	Su verificacion esta condicionada a la definicion del canal de entrega del token (H-14); hasta entonces solo puede verificarse la vigencia y el uso unico del token.	20
REQ-13	R-08 (Medio - 6)	**Media**	Funcionalidad de consulta sin impacto sobre la integridad del dinero. Verificable con un conjunto acotado de valores limite de paginacion.	21
REQ-22	R-01 (Critico - 25)	**Media**	Pertenece al riesgo de exposicion, pero la configuracion ya fue verificada como valida durante el analisis, por lo que solo resta la confirmacion funcional desde el navegador.	22
REQ-23	R-12 (Alto - 12)	**Media**	Su verificacion es de naturaleza continua a traves del pipeline y no requiere una ventana dedicada de ejecucion.	23
REQ-24	R-13 (Bajo - 3)	**Baja**	Menor riesgo del alcance y sin criterios de referencia disponibles. Se ejecuta al final, de modo que si el tiempo se agota sea lo unico que quede sin cubrir.	24

La consecuencia practica de este orden es que, si el tiempo del ciclo se agota antes de completar la ejecucion, lo que queda sin probar es siempre lo de menor consecuencia para el negocio. Esa es precisamente la finalidad de un enfoque basado en riesgos: no eliminar la incertidumbre, sino asegurar que la incertidumbre residual recaiga sobre lo menos importante.

19. Conclusiones

Principales riesgos identificados

El analisis produjo quince riesgos, de los cuales tres alcanzaron nivel Critico, seis nivel Alto, cinco nivel Medio y uno nivel Bajo. El riesgo dominante es R-01 (25 puntos): la exposicion de endpoints sin control de autorizacion, que no es una hipotesis sino un hecho verificado, y que ademas revela credenciales de integracion de bancos socios. Le siguen R-04 (20 puntos), la evasion del limite de retiro diario por inconsistencia de la regla entre canales, tambien confirmada por analisis del codigo, y R-09 (20 puntos), la posibilidad de que una transferencia ACH saliente debite fondos sin acreditarlos en destino ante un fallo de integracion no especificado. Es significativo que los dos primeros riesgos no sean potenciales sino defectos ya confirmados durante la fase de analisis, antes de ejecutar un solo caso de prueba.

Funcionalidades que requieren mayor atencion

El canal ACH concentra la mayor densidad de riesgo del sistema: reune el defecto de control de acceso, la ausencia de especificacion del manejo de fallos y la dependencia de terceros fuera del control del equipo. En segundo lugar, el conjunto formado por la transferencia interna, el retiro y la transferencia desde el portal, porque implementan la misma regla de negocio de tres formas distintas y por tanto exigen verificacion comparativa entre canales en lugar de verificacion aislada. En tercer lugar, el modulo de seguridad, por ser el control que sostiene la validez de todos los demas.

Problemas encontrados en los requerimientos

Se registraron quince hallazgos: tres de severidad Critica, cuatro de severidad Alta y ocho de severidad Media. La revision de los veinticuatro requerimientos mostro que solo siete resultaron simultaneamente claros, completos, verificables y consistentes. Siete presentan ambiguedades, nueve estan incompletos y tres tienen defectos ya confirmados. El problema de fondo es transversal y esta recogido en H-01: no existe una base de prueba formal, por lo que el codigo fuente opera como sustituto de la especificacion. Esto permite verificar que el sistema es internamente consistente, pero no que haga lo que el negocio necesita.

Informacion adicional que necesita QA

Con caracter bloqueante: la definicion del umbral y la duracion del bloqueo por intentos fallidos (H-02), el comportamiento esperado ante un descuadre en el cierre de caja (H-07) y el manejo de fallos en la integracion ACH saliente (H-06). Con caracter importante pero no bloqueante: la validacion por el area de negocio de los parametros financieros por defecto, la confirmacion de si la exencion del limite diario para cuentas MONETARIA es deliberada, la definicion de topes maximos por transaccion y los niveles de servicio no funcionales.

Recursos criticos

El recurso mas critico no es una herramienta sino una persona: la disponibilidad del Product Owner para resolver las definiciones pendientes, porque de ella dependen tres requerimientos criticos. En segundo lugar, la disponibilidad y estabilidad de la base de datos remota compartida, cuya indisponibilidad detiene por completo la ejecucion. En tercer lugar, el tiempo del equipo: cuatro semanas con dedicacion parcial obligaron a excluir tres modulos completos del alcance y a asumir de forma explicita el riesgo residual correspondiente.

Condiciones que podrian impedir el inicio de las pruebas

Tres condiciones tienen hoy estado no satisfecho. La primera y mas inmediata es la ausencia de datos de prueba: el ambiente levantado no tiene clientes, cuentas ni bancos ACH configurados, por lo que ningun escenario de negocio puede ejecutarse (H-15); su resolucion es de bajo esfuerzo porque los scripts semilla ya existen. La segunda es la falta de las definiciones de negocio bloqueantes. La tercera es que el defecto de

control de acceso del modulo ACH permanezca sin corregir, lo que obligaria a ejecutar sobre una version que ya se sabe defectuosa.

Condiciones para el cierre de las pruebas

El cierre exige que se cumplan de forma simultanea: cobertura del cien por ciento de los casos de requerimientos criticos y del noventa por ciento del alcance total; cero defectos criticos abiertos y un maximo de dos defectos altos, unicamente con solucion temporal documentada y aceptacion escrita del Product Owner; suite de regresion en verde incluyendo los casos incorporados durante el ciclo; matriz de control de acceso completa sin ningun endpoint que responda sin autenticacion; y evidencia de que las reglas financieras producen el mismo resultado en los tres canales, o bien aceptacion formal de la diferencia como regla de negocio.

Influencia de los riesgos sobre la estrategia

Los riesgos no fueron un anexo del plan sino su principal criterio de diseno, y determinaron cuatro decisiones concretas. Primero, el alcance: los modulos de Contabilidad, RRHH y Catalogos quedaron fuera por presentar riesgo bajo o diferido, mientras el canal ACH entro pese a su complejidad por concentrar el riesgo maximo. Segundo, los tipos de prueba: la seguridad funcional se incorporo con prioridad critica como consecuencia directa de R-01, y el rendimiento se excluyo por la combinacion de impacto moderado y ausencia de ambiente representativo. Tercero, las tecnicas: los valores limite y la tabla de decision se reservaron para las operaciones que mueven dinero, donde los riesgos R-03 y R-04 se materializan en las fronteras. Cuarto, el orden de ejecucion, que sigue el nivel de riesgo de forma descendente para garantizar que, si el tiempo se agota, lo no ejecutado sea siempre lo de menor consecuencia.

20. Preguntas de reflexion

1. Que ocurriria si QA comenzara a disenar casos de prueba sin analizar previamente los requerimientos

El equipo habria disenado casos sobre supuestos falsos y habria perdido la oportunidad de detectar defectos en el momento mas barato del ciclo. Este proyecto lo ilustra de forma concreta: el analisis previo revelo que el limite de retiro diario se implementa de tres maneras distintas segun el canal. Sin ese analisis, un tester habria disenado un unico caso, lo habria ejecutado en ventanilla, habria obtenido un resultado aprobado y habria concluido que la regla funciona, sin detectar jamas que por otro canal el control simplemente no existe. El defecto habria llegado a produccion con un caso de prueba en verde respaldandolo. Ademas se habrian disenado casos para los requerimientos REQ-02, REQ-09 y REQ-18, que hoy sabemos que carecen de resultado esperado objetivo: todo ese esfuerzo habria sido retrabajo.

2. Por que una funcionalidad de alta prioridad no necesariamente representa el mayor riesgo

Porque la prioridad expresa valor para el negocio, mientras el riesgo combina probabilidad de fallo con impacto del fallo. Una funcionalidad puede ser muy importante y a la vez muy poco riesgosa si es simple, estable y esta bien construida. En este proyecto el contraste es claro: la autenticacion de bancos externos (REQ-20) es de alta prioridad porque sin ella el canal ACH no opera, pero su riesgo residual es moderado porque cuenta con pruebas unitarias verificadas que cubren sus escenarios de rechazo. En cambio, la configuracion de bancos ACH (REQ-17) parece una funcionalidad administrativa secundaria y sin embargo concentra el riesgo maximo del sistema, porque expone credenciales de terceros sin control de acceso. Si el equipo hubiera asignado el esfuerzo solo por prioridad de negocio, habria reforzado lo que ya estaba protegido y habria dejado descubierto el punto mas vulnerable.

3. Que diferencia existe entre probar mucho y probar lo correcto

Probar mucho busca cantidad de casos ejecutados; probar lo correcto busca reduccion efectiva de riesgo. Son objetivos distintos y a menudo opuestos, porque el tiempo invertido en uno se resta del otro. En este plan la diferencia es medible: el equipo excluyo de forma deliberada tres modulos completos (Contabilidad, RRHH y Catalogos) que habrian aportado decenas de casos de prueba faciles de ejecutar y de reportar. Ejecutarlos habria producido un informe con mas casos en verde y mejor apariencia, pero no habria reducido ni un punto los riesgos R-01, R-04 y R-09, que son los que pueden costar dinero real. El principio ISTQB de que las pruebas exhaustivas son imposibles obliga a elegir, y la unica base defendible para elegir es el riesgo. Un plan que prueba todo por igual es, en la practica, un plan que no ha priorizado nada.

4. Por que los criterios de entrada y salida deben ser medibles

Porque un criterio que no se puede medir no se puede verificar, y lo que no se puede verificar termina decidiendose por presion de calendario en lugar de por evidencia. Un criterio como 'el sistema debe funcionar correctamente' no permite decidir nada: cualquier persona puede argumentar que se cumple o que no, y la discusion se resuelve por jerarquia. En cambio, 'cero defectos criticos abiertos y un maximo de dos defectos altos con aceptacion escrita del Product Owner' produce una respuesta verificable y convierte la decision de liberar en una decision de negocio explicita, con un responsable identificado, en lugar de una opinion tecnica difusa. Los criterios medibles protegen al equipo de QA: le permiten sostener una recomendacion de no liberar con datos en lugar de con percepciones.

5. Que problema identificado en los requerimientos podria generar mayor impacto

El hallazgo H-05, la ausencia de control de autorizacion en el modulo ACH, por tres razones acumuladas. Primero, esta confirmado: no es un riesgo potencial sino un comportamiento verificado mediante peticion directa. Segundo, su consecuencia trasciende la organizacion, porque las credenciales expuestas pertenecen a bancos socios y permitirian a un tercero suplantar al banco frente a sus contrapartes. Tercero, y mas grave

desde la perspectiva de QA, revela un problema sistemico y no puntual: la aplicacion no define una politica de autorizacion por defecto, de modo que basta con que un desarrollador omita una anotacion para que un endpoint quede publico sin que nada lo advierta. El defecto visible es un sintoma; la causa raiz puede reproducirse en cualquier modulo futuro. Por eso la accion recomendada no es unicamente agregar el atributo faltante, sino cambiar el valor por defecto del sistema para que la omision falle de forma segura.

6. Como influyeron los riesgos en la estrategia

Los riesgos actuaron como el criterio ordenador de todas las decisiones del plan. Determinaron que entra y que sale del alcance: tres modulos completos se excluyeron por riesgo bajo o diferido, mientras el canal ACH se incluyo pese a su complejidad tecnica por concentrar el riesgo maximo. Determinaron los tipos de prueba: la seguridad funcional paso a prioridad critica como consecuencia directa de R-01, y el rendimiento se excluyo tras evaluar que su impacto era moderado y que el ambiente no permitiria obtener resultados representativos. Determinaron las tecnicas: los valores limite y la tabla de decision se concentraron en las operaciones que mueven dinero, porque es ahi donde los riesgos R-03 y R-04 se materializan en las fronteras de los importes. Y determinaron el orden de ejecucion, que sigue el nivel de riesgo de forma descendente para que, si el tiempo se agota, lo que quede sin ejecutar sea siempre lo de menor consecuencia.

7. Que decision del equipo tuvo mayor impacto en la planificacion

La decision de tratar el codigo fuente y los scripts SQL como base de prueba formal, en lugar de detener la planificacion ante la ausencia de historias de usuario. Fue la decision de mayor impacto porque cambio por completo el resultado de la entrega: permitio derivar veinticuatro requerimientos verificables, extraer los valores limite reales (saldo minimo de Q100.00, limite diario de Q5,000.00) y descubrir mediante analisis estatico dos defectos confirmados antes de ejecutar un solo caso. La alternativa, esperar a que existiera documentacion formal, habria consumido el Sprint completo sin producir valor. La decision tiene un costo que el equipo asume de forma explicita y documenta en H-01: al usar el codigo como especificacion, QA puede verificar consistencia interna pero no correccion de negocio. Por eso la decision se acompano del compromiso de registrar cada supuesto asumido y de escalar al Product Owner la construccion de un backlog minimo.

8. Que informacion necesitaria QA antes de comenzar la siguiente fase

En orden de urgencia: primero, las tres definiciones de negocio bloqueantes (umbral de bloqueo, comportamiento ante descuadre de caja y manejo de fallos ACH), sin las cuales no es posible establecer el resultado esperado de tres requerimientos criticos. Segundo, la confirmacion del area de negocio sobre cual es la regla valida de limite de retiro diario y si la exencion de las cuentas MONETARIA es deliberada, porque de ello depende si el hallazgo H-03 se clasifica como defecto o como regla no documentada. Tercero, la confirmacion de los parametros financieros por defecto y la definicion de topes maximos por transaccion, necesarias para cerrar el diseno de los casos de valores limite. Cuarto, la confirmacion de que los datos semilla fueron cargados en el ambiente, por ser condicion de entrada bloqueante.

21. Trazabilidad entre las decisiones

La cadena de trazabilidad exigida por el proyecto se construyo de forma efectiva en esta entrega hasta el nivel de priorizacion. El siguiente ejemplo recorre la cadena completa sobre el caso real de mayor riesgo del sistema, mostrando como cada eslabon se deriva del anterior y donde queda el punto de continuidad para la Entrega 2.

Eslabon de la cadena	Contenido concreto en este proyecto	Seccion
Requerimiento	REQ-12: Registrar una transferencia entre dos cuentas internas.	5, 6
Analisis	El procedimiento sp_transferir_fondos no valida ni acumula el limite de retiro diario, a diferencia de sp_retiro y del servicio del portal. Verificado por analisis del codigo SQL versionado.	5.1

Eslabon de la cadena	Contenido concreto en este proyecto	Seccion
Hallazgo	H-03 (severidad Alta): la misma regla de negocio esta implementada de tres formas divergentes segun el canal.	17
Riesgo	R-04 (nivel Critico, 20 puntos): evasion del limite de retiro diario por inconsistencia de la regla entre canales.	7.1
Prioridad	Prioridad Critica, orden de ejecucion 3 de 24.	18
Estrategia	Diseno de casos comparativos que ejecutan la misma operacion en los tres canales y contrastan los resultados, mediante tabla de decision y analisis de valores limite.	8.1, 8.2
Criterio de salida	Las reglas de saldo minimo, saldo disponible y limite diario producen el mismo resultado en los tres canales, o la diferencia esta aceptada formalmente por el Product Owner.	10.2
Condicion de prueba	Pendiente - Entrega 2	-
Caso de prueba	Pendiente - Entrega 2	-
Ejecucion, defecto y reprueba	Pendiente - Entregas 3 y 4	-

22. Fuentes consultadas

Las fuentes se listan indicando de forma explicita para que se utilizo cada una dentro de este documento. Todas son verificables y corresponden a organismos de estandarizacion, documentacion oficial de los productos empleados o literatura academica reconocida.

Autor / Organismo	Referencia	Uso dentro de este documento
International Software Testing Qualifications Board (ISTQB)	Certified Tester Foundation Level Syllabus v4.0. ISTQB, 2023. Disponible en https://www.istqb.org/certifications/certified-tester-foundation-level	Fuente normativa principal. Se utilizo para estructurar las actividades de planificacion y analisis de pruebas, los niveles y tipos de prueba, las tecnicas de diseno y los siete principios de las pruebas citados en las conclusiones y la reflexion.
International Software Testing Qualifications Board (ISTQB)	Certified Tester Advanced Level Test Manager Syllabus v3.0. ISTQB, 2021. Disponible en https://www.istqb.org/certifications/test-manager	Se utilizo para el enfoque de pruebas basado en riesgos, el calculo del nivel de riesgo como producto de probabilidad por impacto y la definicion de criterios de entrada y salida medibles.
International Software Testing Qualifications Board (ISTQB)	ISTQB Glossary of Testing Terms, v4.x. Disponible en https://glossary.istqb.org/	Se utilizo para asegurar el uso preciso y consistente de la terminologia tecnica a lo largo del documento (base de prueba, condicion de prueba, criterio de salida, riesgo de producto).
International Organization for Standardization / IEEE	ISO/IEC/IEEE 29119-3:2021. Software and systems engineering - Software testing - Part 3: Test documentation. Disponible en https://www.iso.org/standard/79430.html	Se utilizo como referencia para la estructura y el contenido minimo del Master Test Plan y de la documentacion de pruebas asociada.
International Organization for Standardization / IEC	ISO/IEC 25010:2011. Systems and software Quality Requirements and Evaluation (SQuaRE) - System and software quality models. Disponible en https://www.iso.org/standard/35733.html	Se utilizo como marco para clasificar las caracteristicas de calidad evaluadas: adecuacion funcional, seguridad, fiabilidad y usabilidad.
Open Worldwide Application Security Project (OWASP)	OWASP Top 10:2021 - A01 Broken Access Control y A07 Identification and Authentication Failures. Disponible en https://owasp.org/Top10/	Se utilizo para clasificar y fundamentar la severidad de los hallazgos H-05 (control de acceso deficiente) y H-08 (debilidades en el flujo de autenticacion).
Open Worldwide Application Security Project (OWASP)	OWASP Web Security Testing Guide v4.2. Disponible en https://owasp.org/www-project-web-security-testing-guide/	Se utilizo como referencia metodologica para el diseno de la matriz de control de acceso y de las pruebas de autorizacion vertical y horizontal.
Microsoft	Documentacion oficial de ASP.NET Core: Authorization in ASP.NET Core y Policy-based authorization. Disponible en https://learn.microsoft.com/aspnet/core/security/authorization/	Se utilizo para verificar el comportamiento del mecanismo de autorizacion y fundamentar de forma tecnica la recomendacion de definir una politica de autorizacion por defecto en el hallazgo H-05.
The PostgreSQL Global Development Group	PostgreSQL 17 Documentation: Chapter 13 Concurrency Control y Chapter 43 PL/pgSQL. Disponible en https://www.postgresql.org/docs/current/	Se utilizo para fundamentar el analisis de atomicidad e integridad transaccional de los procedimientos almacenados y el diseno de las pruebas de concurrencia.
Boehm, B. W.	Software Engineering Economics. Prentice Hall, 1981.	Referencia academica clasica sobre el crecimiento del

Autor / Organismo	Referencia	Uso dentro de este documento
		costo de correccion de un defecto segun la fase en que se detecta. Fundamenta el argumento central de la pregunta de reflexion numero 1.
Myers, G. J., Sandler, C. y Badgett, T.	The Art of Software Testing. 3a edicion. John Wiley & Sons, 2011.	Referencia academica sobre las tecnicas de diseno de casos de prueba aplicadas en la estrategia: particion de equivalencia, analisis de valores limite y tablas de decision.
Repositorio del proyecto BancoERP	banco-erp-umg. Universidad Mariano Galvez, 2026. Rama main, commit 28f3faf. Codigo fuente, scripts de base de datos y configuracion de despliegue.	Fuente primaria del analisis. Constituye la base de prueba efectiva del proyecto (artefactos BT-01 a BT-09) ante la ausencia de especificacion formal.

Anexo A. Evidencias de la exploracion del sistema

Las evidencias siguientes se obtuvieron el 15 de septiembre de 2026 sobre el ambiente descrito en la seccion 13, levantado mediante Docker Compose a partir del commit 28f3faf. Constituyen el artefacto BT-09 de la base de prueba y sustentan los hallazgos H-02, H-05, H-08 y H-15.

Evidencia A.1 - Pantalla de inicio de sesion

Punto de entrada del sistema. Muestra el campo rotulado 'Usuario o correo', cuya ambiguedad respecto del contrato del API se documenta en el hallazgo H-04.

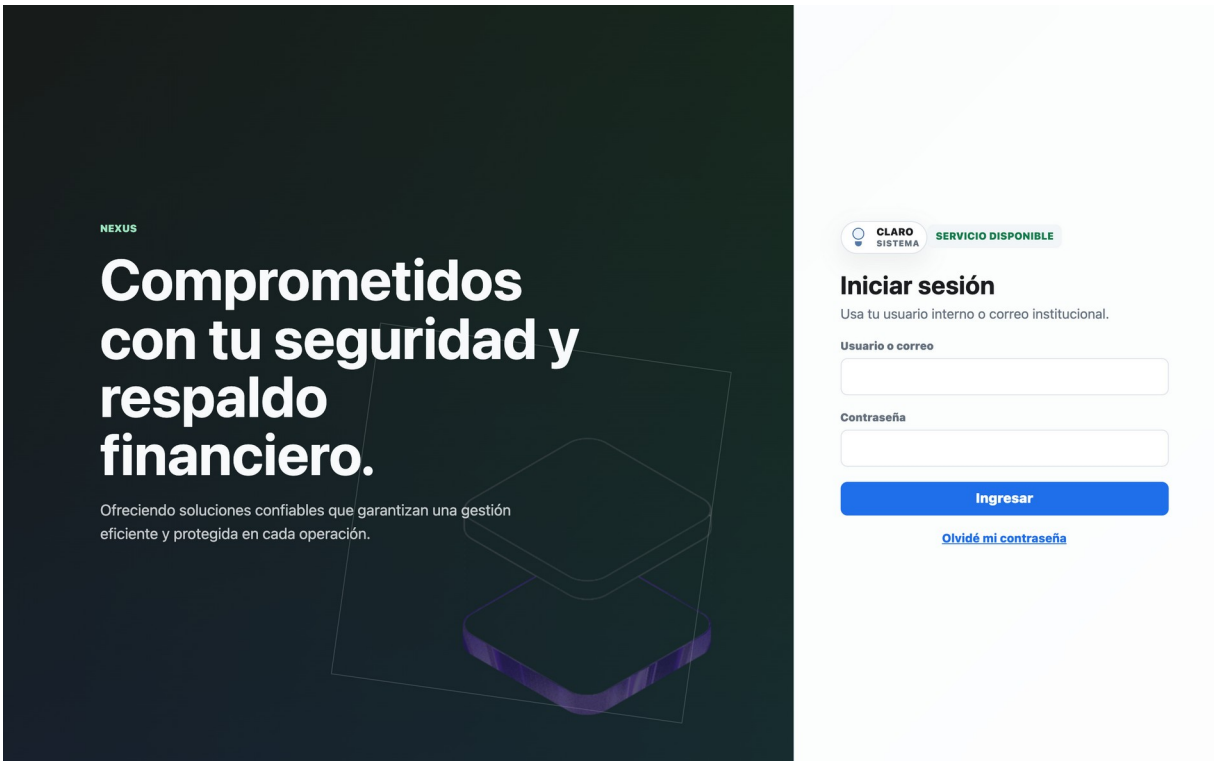


Figura A.1. Pantalla de inicio de sesion. Captura del ambiente de QA, 15-09-2026.

Evidencia A.2 - Bloqueo progresivo por intentos fallidos

Evidencia del hallazgo H-02 y H-08. El mensaje en linea revela 'Credenciales incorrectas. Intento 1 de 5', lo que confirma que el ambiente usa un umbral de 5 mientras el codigo define 3 por defecto, y expone el contador al usuario. Se observa ademas la inconsistencia con la notificacion emergente, que muestra un mensaje distinto de forma simultanea.

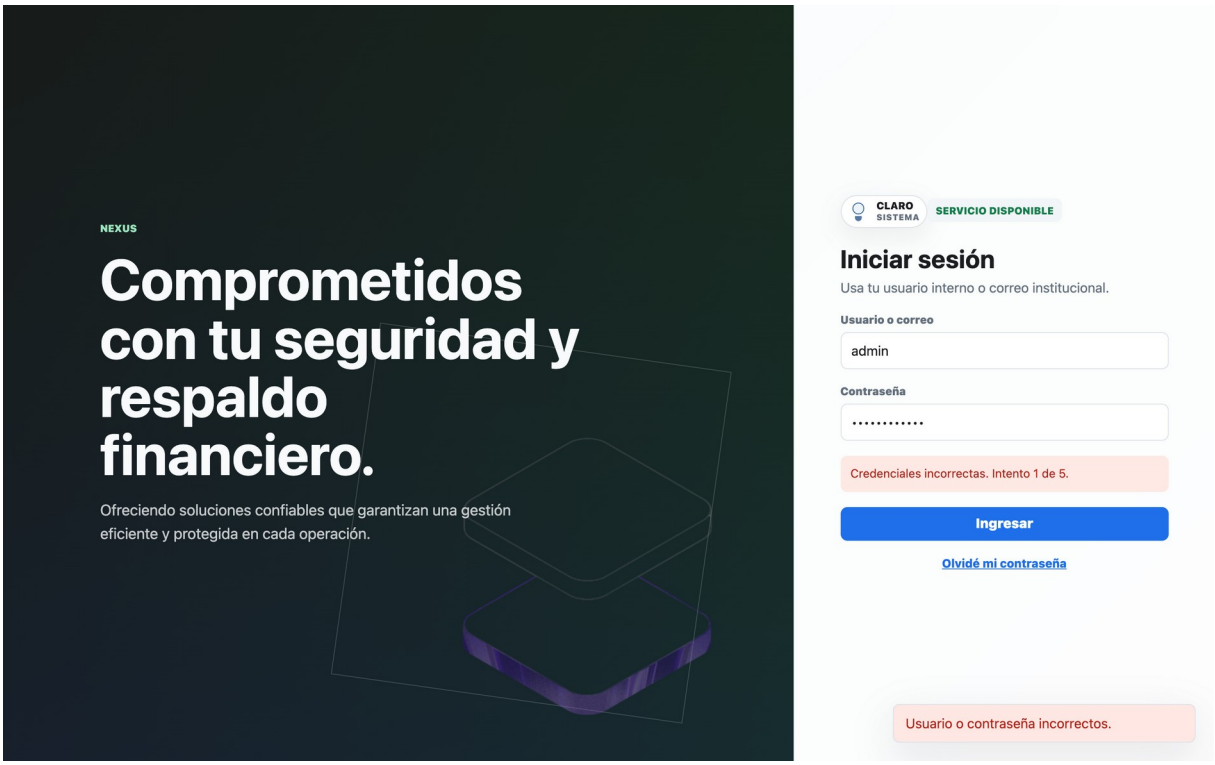


Figura A.2. Bloqueo progresivo por intentos fallidos. Captura del ambiente de QA, 15-09-2026.

Evidencia A.3 - Centro operativo (tablero administrativo)

Evidencia del hallazgo H-15: el tablero muestra 'Sin datos disponibles' y saldos en Q0.00, confirmando que los criterios de entrada relativos a datos de prueba no estan satisfechos.

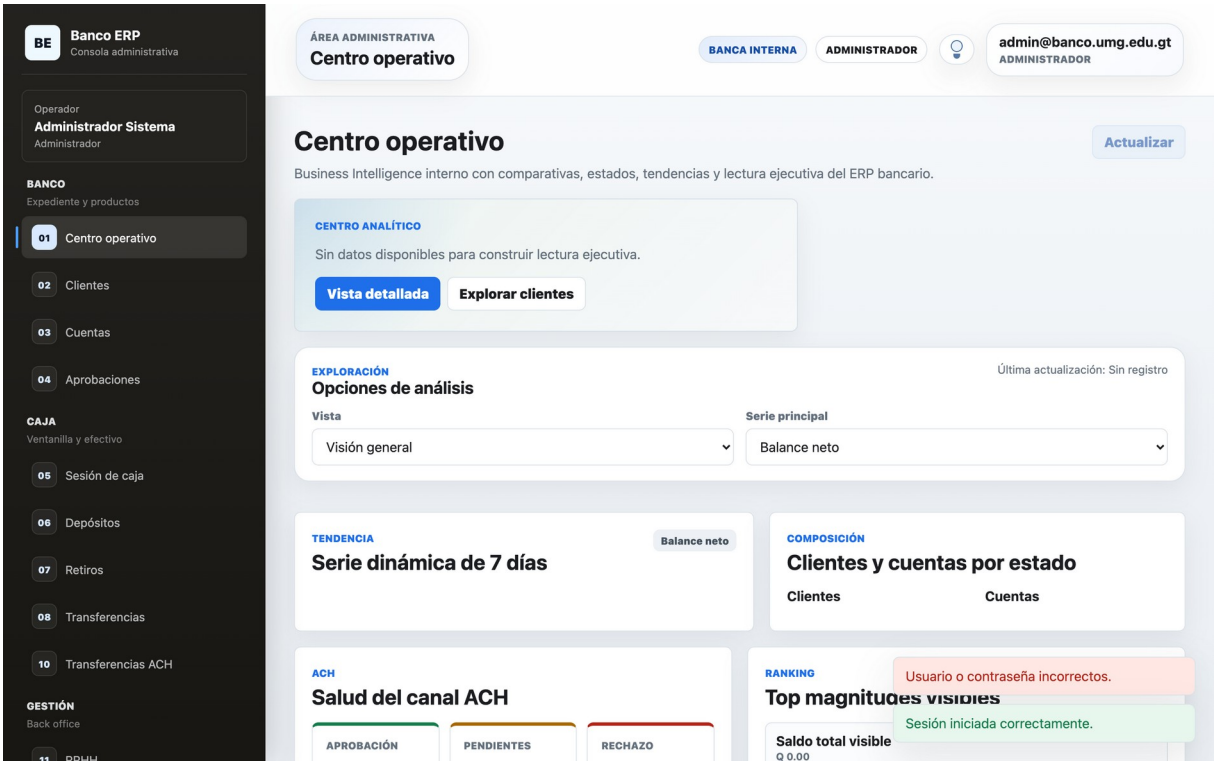


Figura A.3. Centro operativo (tablero administrativo). Captura del ambiente de QA, 15-09-2026.

Evidencia A.4 - Modulo CRM - Gestion de clientes

Alcance de REQ-14 y del flujo de aprobacion. El estado del cliente es precondicion de la apertura de cuentas y de la transferencia desde el portal.

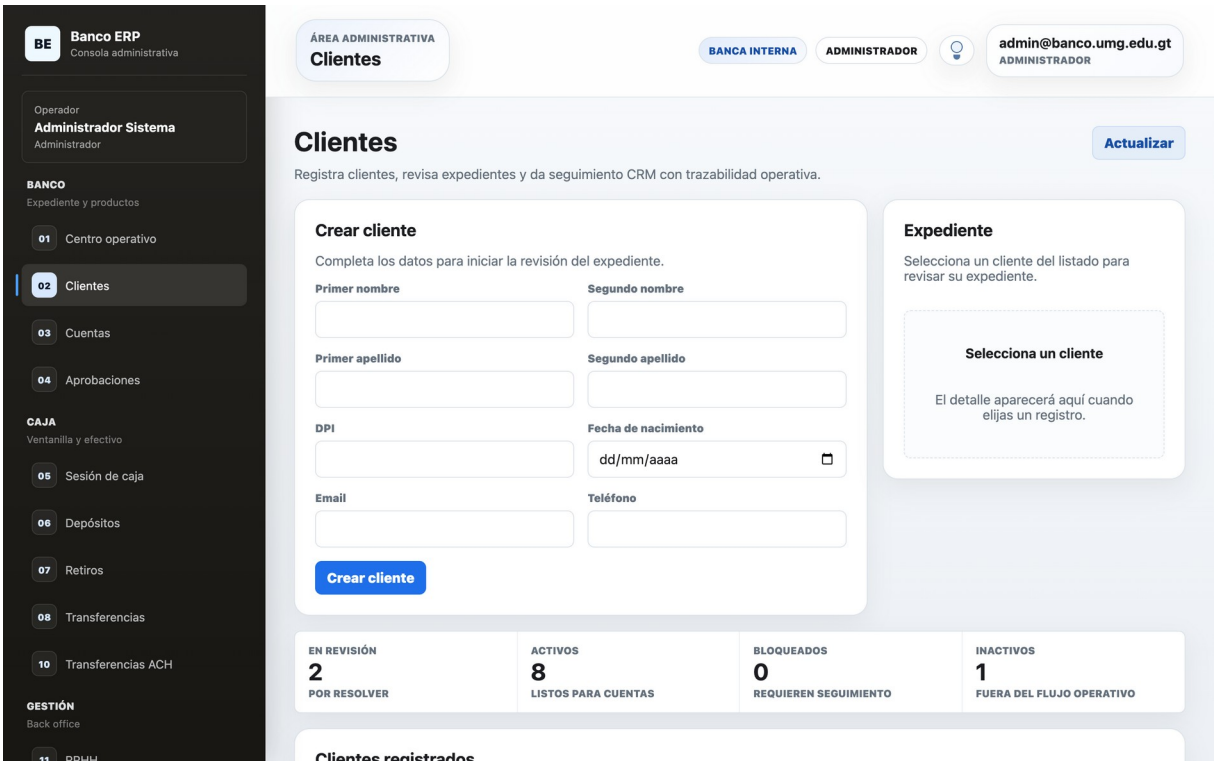


Figura A.4. Modulo CRM - Gestion de clientes. Captura del ambiente de QA, 15-09-2026.

Evidencia A.5 - Modulo de cuentas

Pantalla donde se configuran los parametros que gobiernan las transacciones: saldo minimo y limite de retiro diario, fronteras centrales del diseno de valores limite.

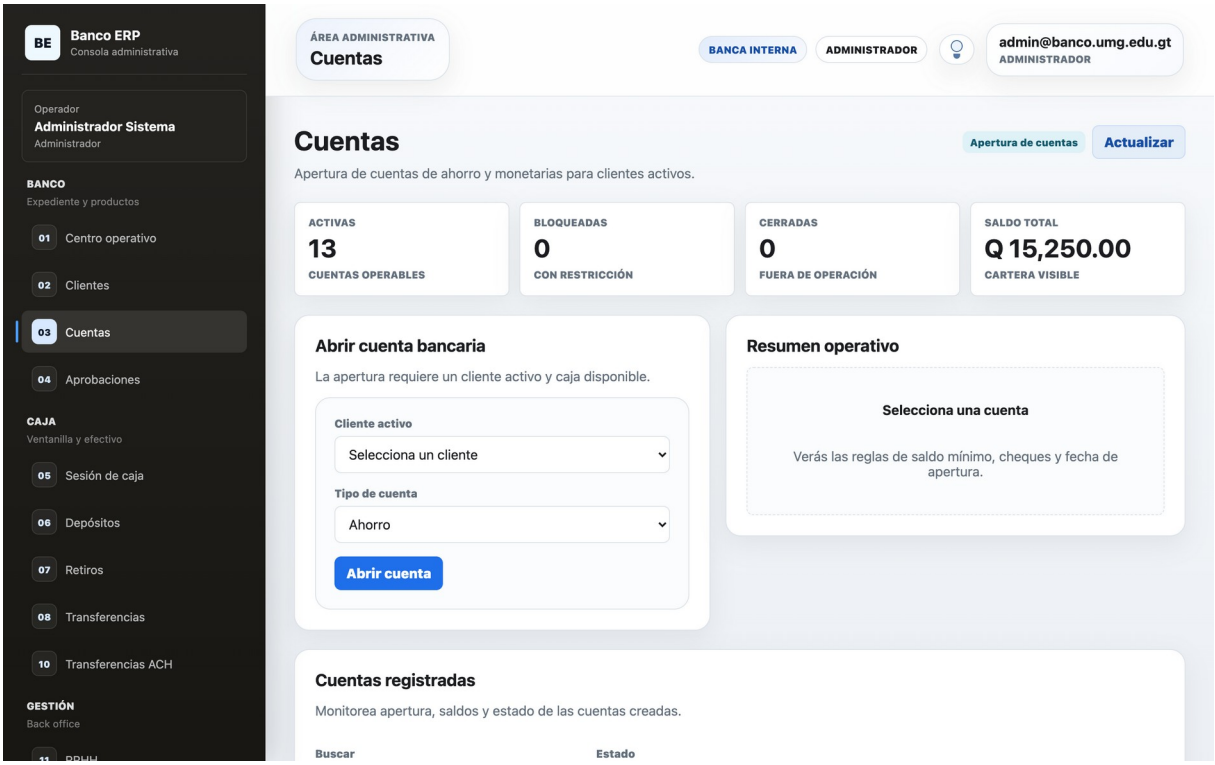


Figura A.5. Modulo de cuentas. Captura del ambiente de QA, 15-09-2026.

Evidencia A.6 - Transacciones - Deposito en ventanilla

Corresponde a REQ-10. La operacion exige caja abierta y monto mayor que cero.

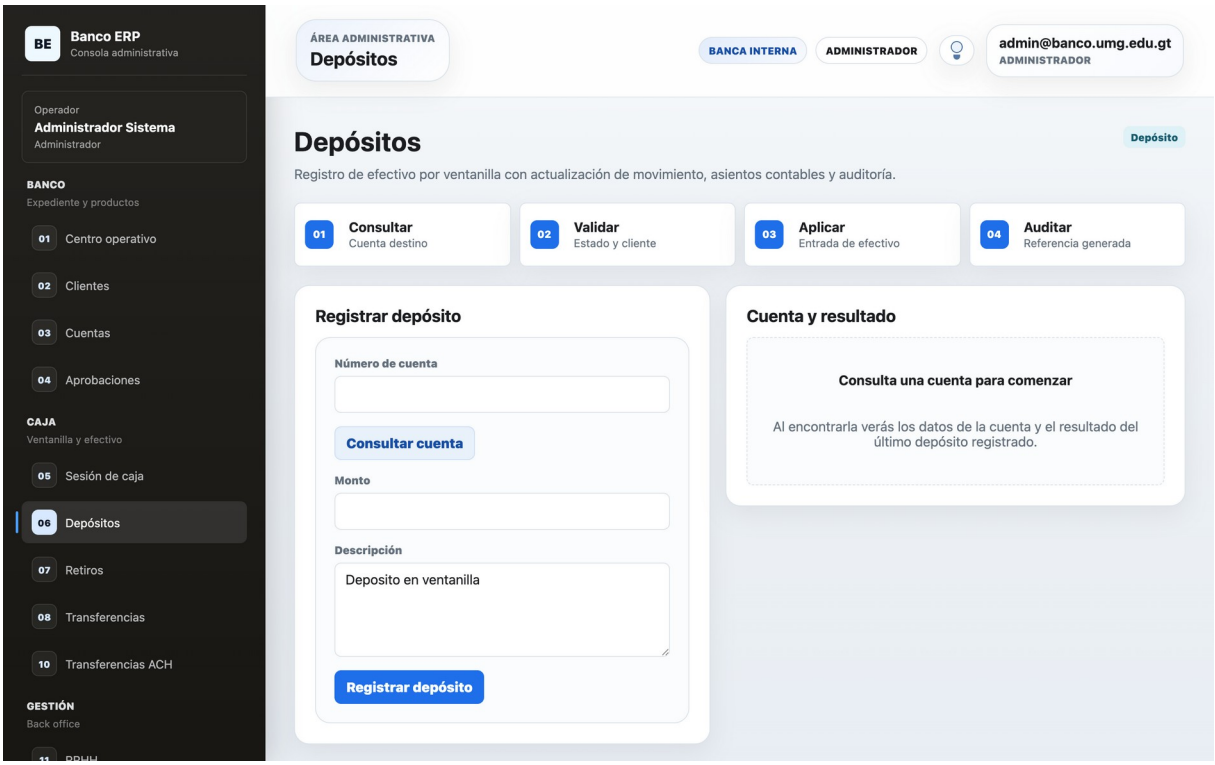


Figura A.6. Transacciones - Deposito en ventanilla. Captura del ambiente de QA, 15-09-2026.

Evidencia A.7 - Transacciones - Retiro en ventanilla

Corresponde a REQ-11, la operacion con mayor densidad de reglas de frontera: saldo disponible, saldo minimo y limite diario aplicable solo a cuentas AHORRO.

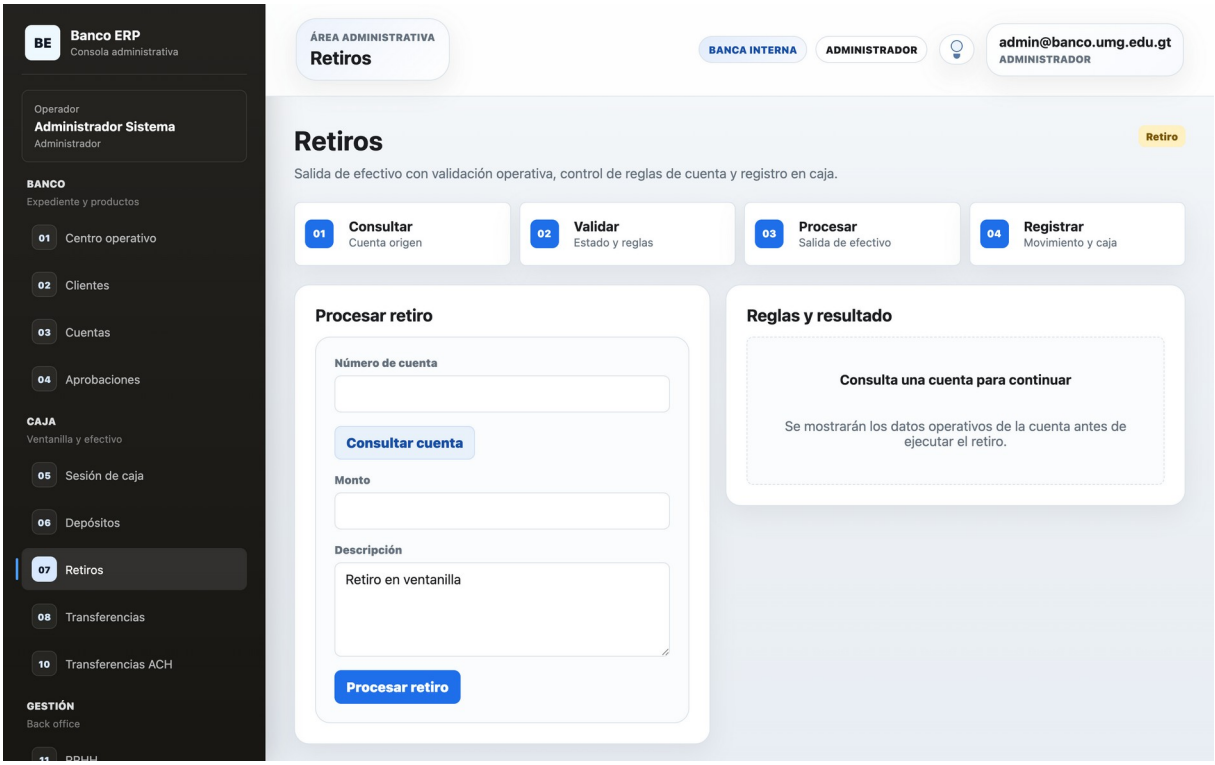


Figura A.7. Transacciones - Retiro en ventanilla. Captura del ambiente de QA, 15-09-2026.

Evidencia A.8 - Transacciones - Transferencia interna

Corresponde a REQ-12. Es el canal donde se confirmo la ausencia de validacion del limite de retiro diario documentada en el hallazgo H-03.

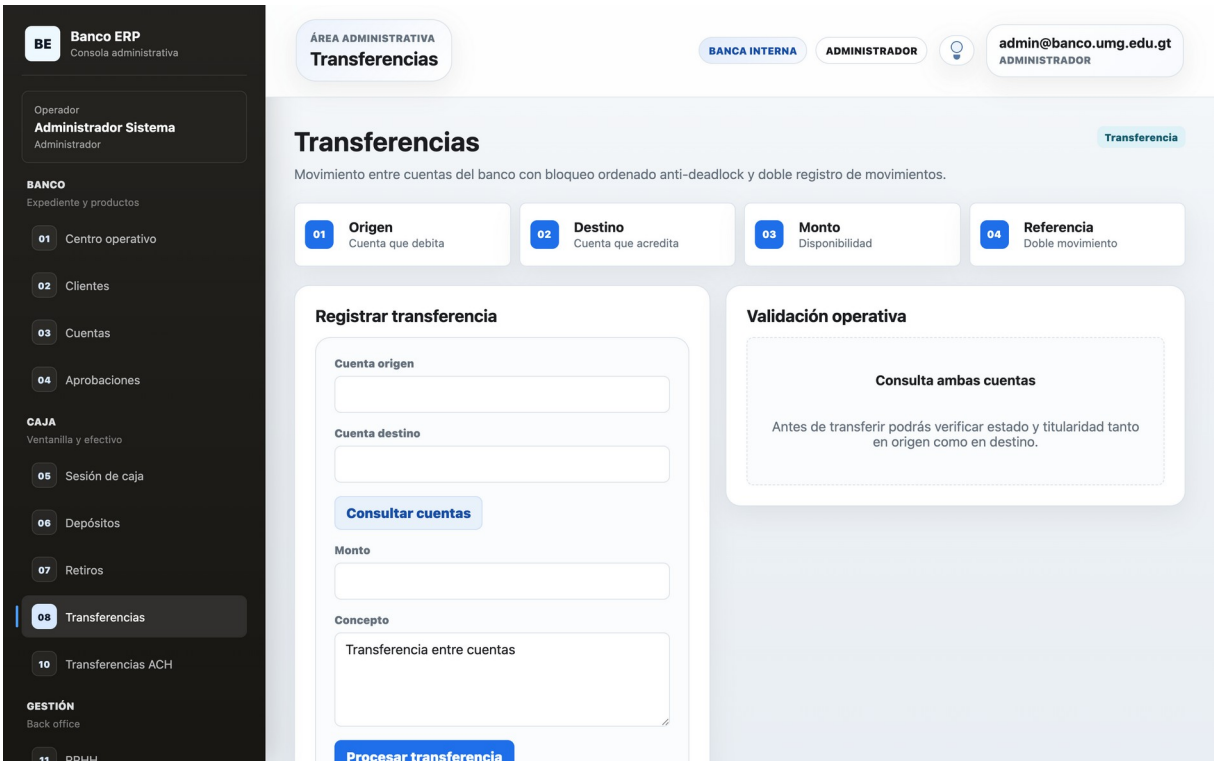


Figura A.8. Transacciones - Transferencia interna. Captura del ambiente de QA, 15-09-2026.

Evidencia A.9 - Modulo de caja - Apertura, estado y cierre

Corresponde a REQ-08 y REQ-09. Se observa la formula del efectivo esperado (fondo inicial mas depositos menos retiros) y el estado 'Sin caja abierta', que bloquea toda operacion de ventanilla. El comportamiento ante descuadre no esta definido (H-07).

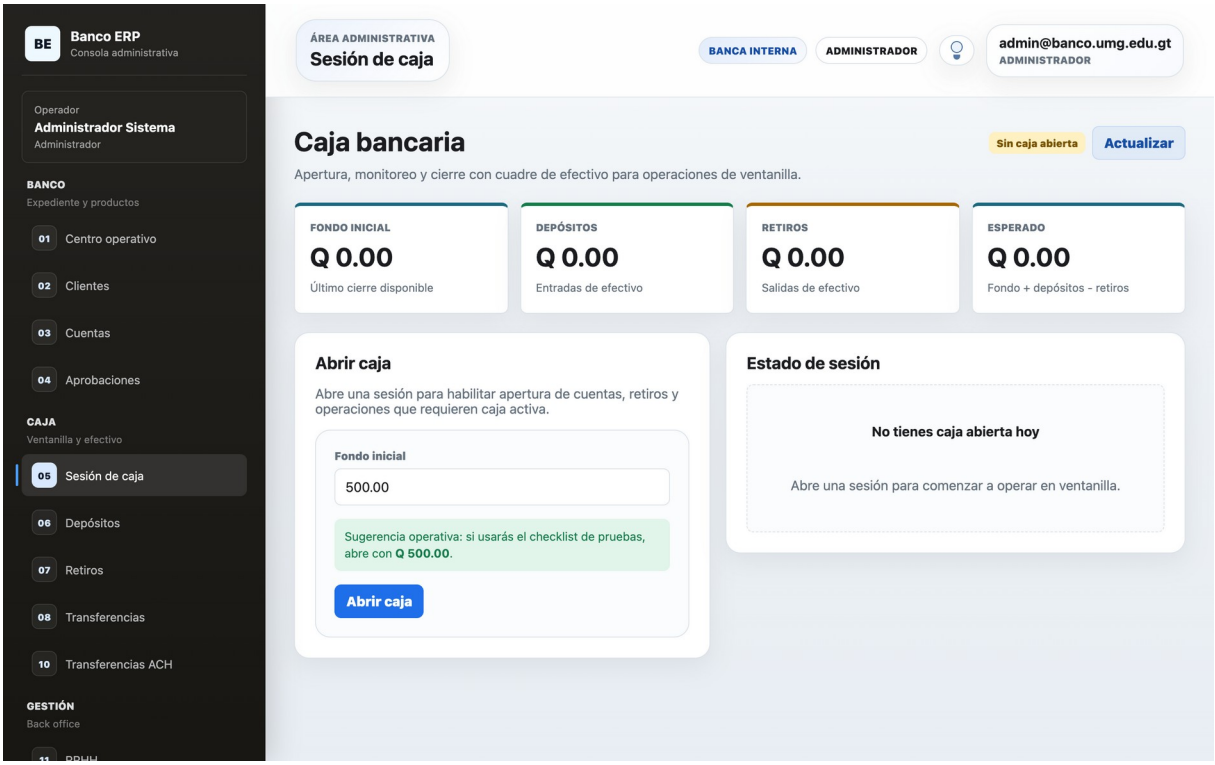


Figura A.9. Modulo de caja - Apertura, estado y cierre. Captura del ambiente de QA, 15-09-2026.

Evidencia A.10 - ACH - Configuracion de bancos externos

Corresponde a REQ-17. Es el modulo cuyo endpoint responde sin autenticacion y expone credenciales de integracion (H-05). Se observa ademas cero bancos configurados, evidencia complementaria del hallazgo H-15.

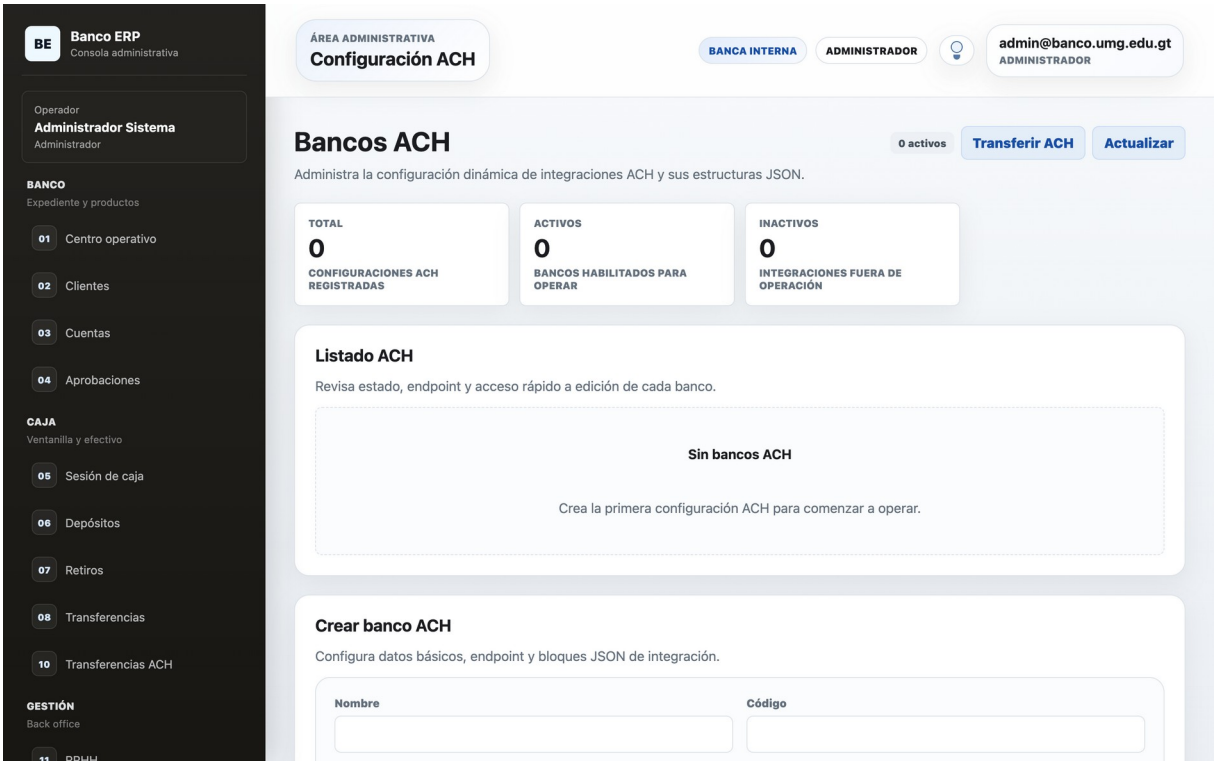


Figura A.10. ACH - Configuracion de bancos externos. Captura del ambiente de QA, 15-09-2026.

Evidencia A.11 - ACH - Transferencias interbancarias salientes

Corresponde a REQ-18, el requerimiento de mayor riesgo economico y menor verificabilidad por la ausencia de especificacion del manejo de fallos (H-06).

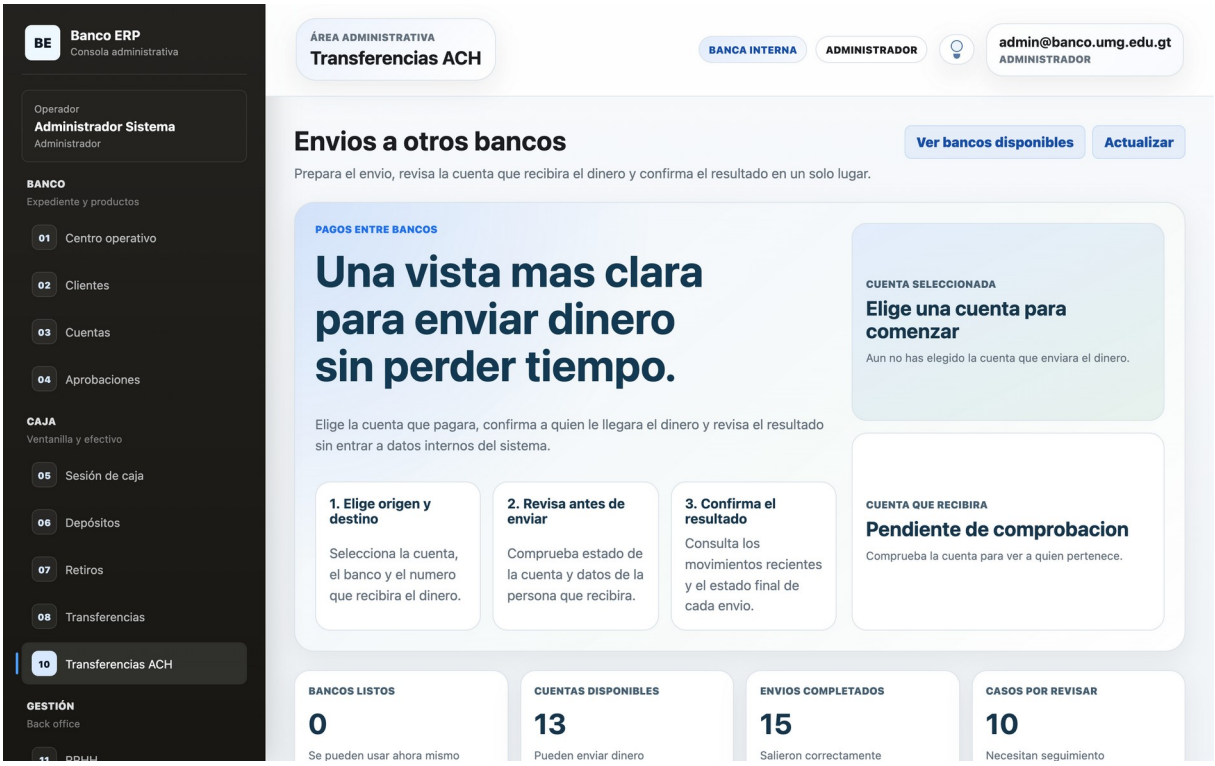


Figura A.11. ACH - Transferencias interbancarias salientes. Captura del ambiente de QA, 15-09-2026.

Evidencia A.12 - Seguridad - Administracion de usuarios

Soporte de REQ-06. Desde este modulo se construyen los perfiles necesarios para la matriz de control de acceso.

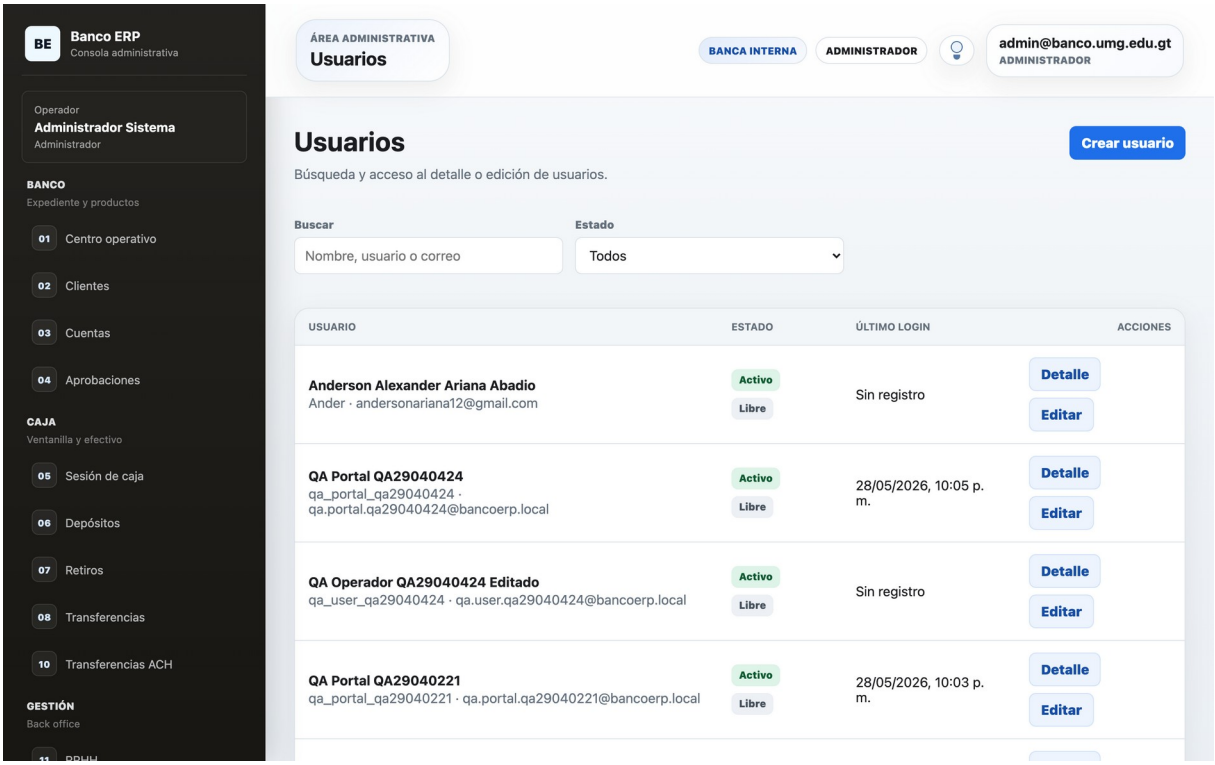


Figura A.12. Seguridad - Administracion de usuarios. Captura del ambiente de QA, 15-09-2026.

Evidencia A.13 - Seguridad - Roles

Soporte de REQ-06. Los roles agrupan los permisos que determinan el acceso efectivo.

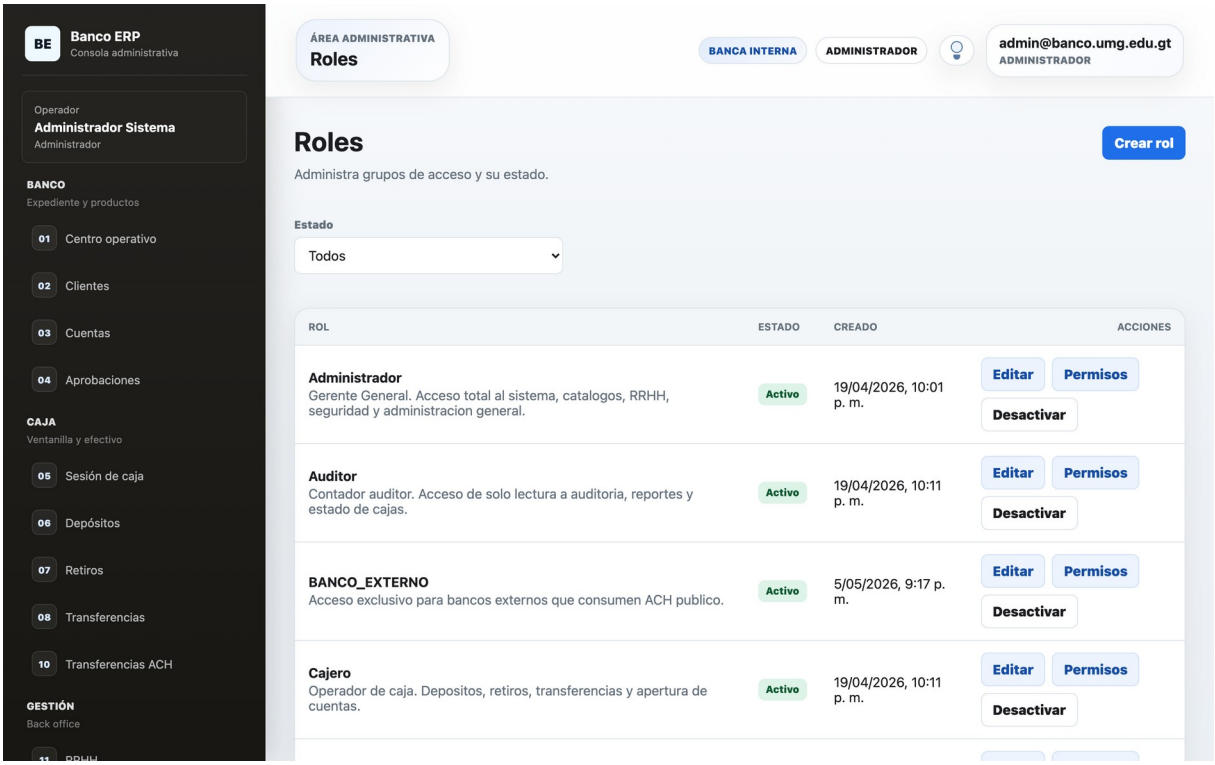


Figura A.13. Seguridad - Roles. Captura del ambiente de QA, 15-09-2026.

Evidencia A.14 - Seguridad - Catalogo de permisos

Los 84 permisos catalogados constituyen la base de la matriz de control de acceso planificada como prueba automatizada.

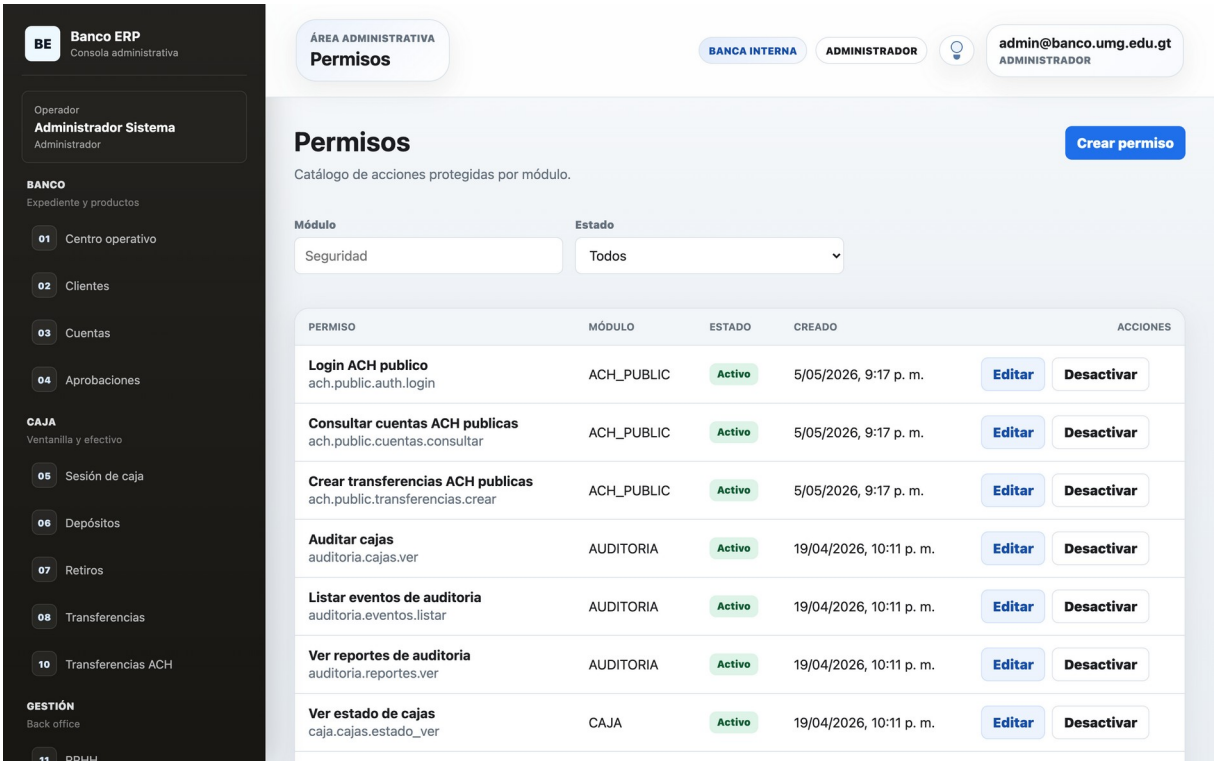


Figura A.14. Seguridad - Catalogo de permisos. Captura del ambiente de QA, 15-09-2026.

Evidencia A.15 - Seguridad - Bitacora de eventos

Corresponde a REQ-07. Registra los 21 tipos de evento auditables. Falta definir la politica de retencion e inmutabilidad.

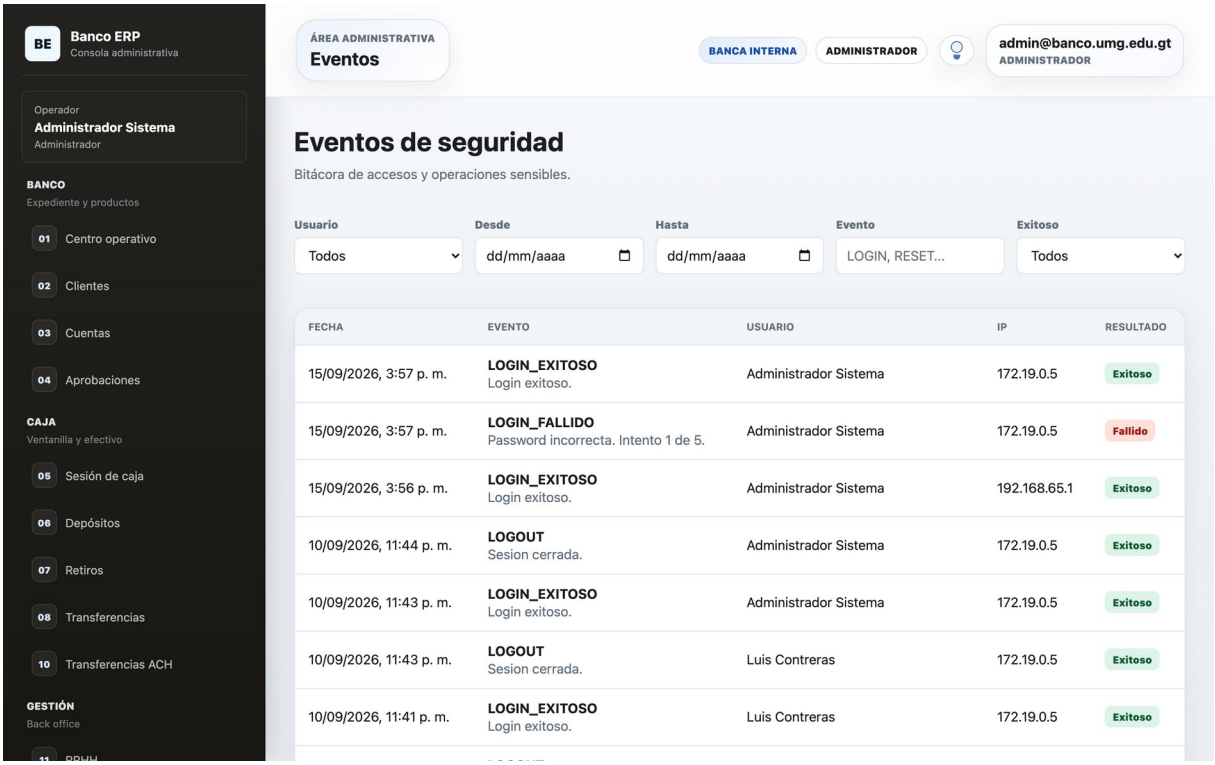


Figura A.15. Seguridad - Bitacora de eventos. Captura del ambiente de QA, 15-09-2026.

Evidencia A.16 - Reportes gerenciales

Modulo de consulta dependiente de la integridad de los datos transaccionales.

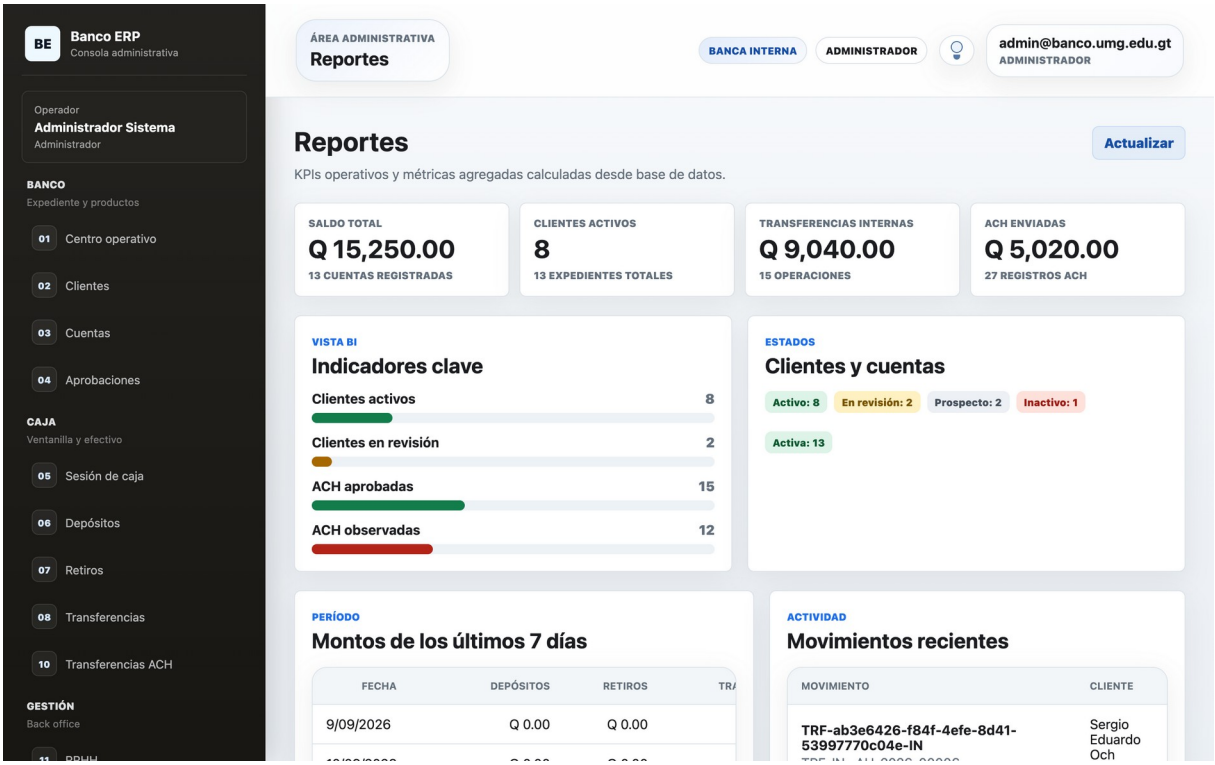


Figura A.16. Reportes gerenciales. Captura del ambiente de QA, 15-09-2026.

Evidencia A.17 - Auditoria de operaciones

Soporte del requisito de trazabilidad regulatoria evaluado en el riesgo R-07.

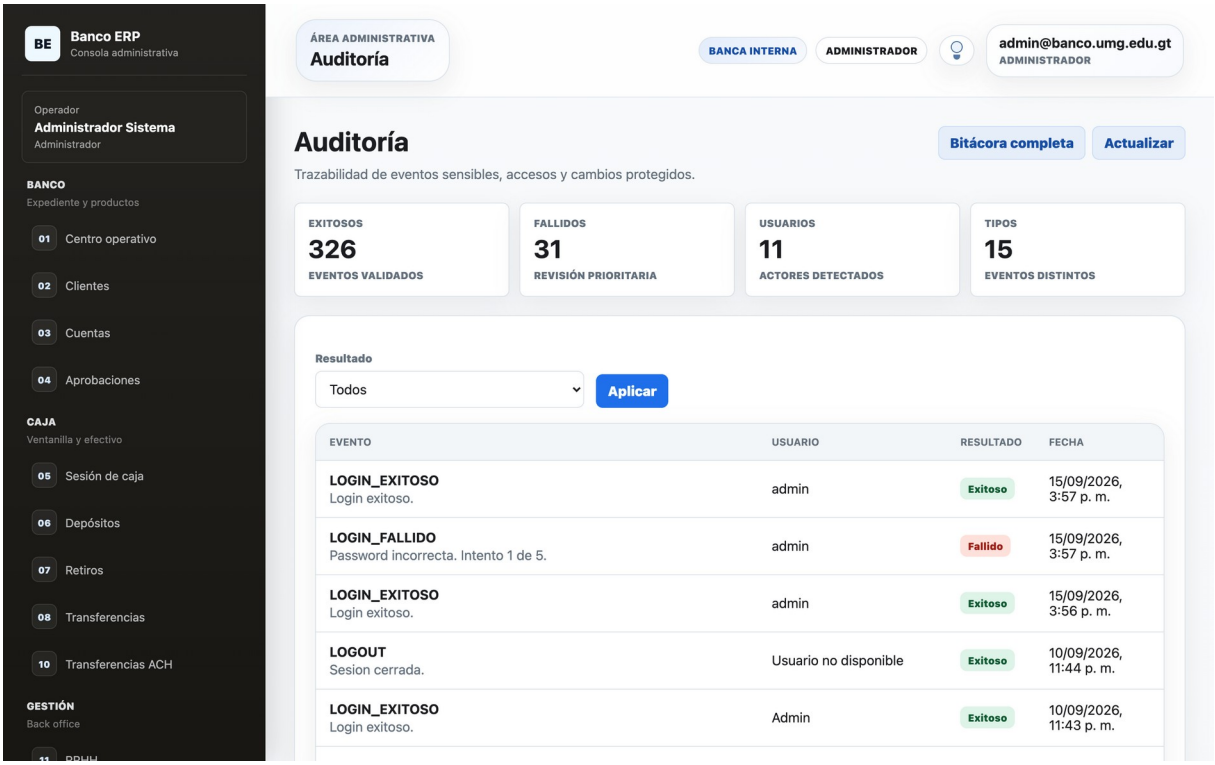


Figura A.17. Auditoria de operaciones. Captura del ambiente de QA, 15-09-2026.

Evidencia A.18 - Modulo de contabilidad

Declarado fuera de alcance en su operacion manual. No obstante, si se verifica la generacion automatica de asientos que disparan las transacciones (REQ-21).

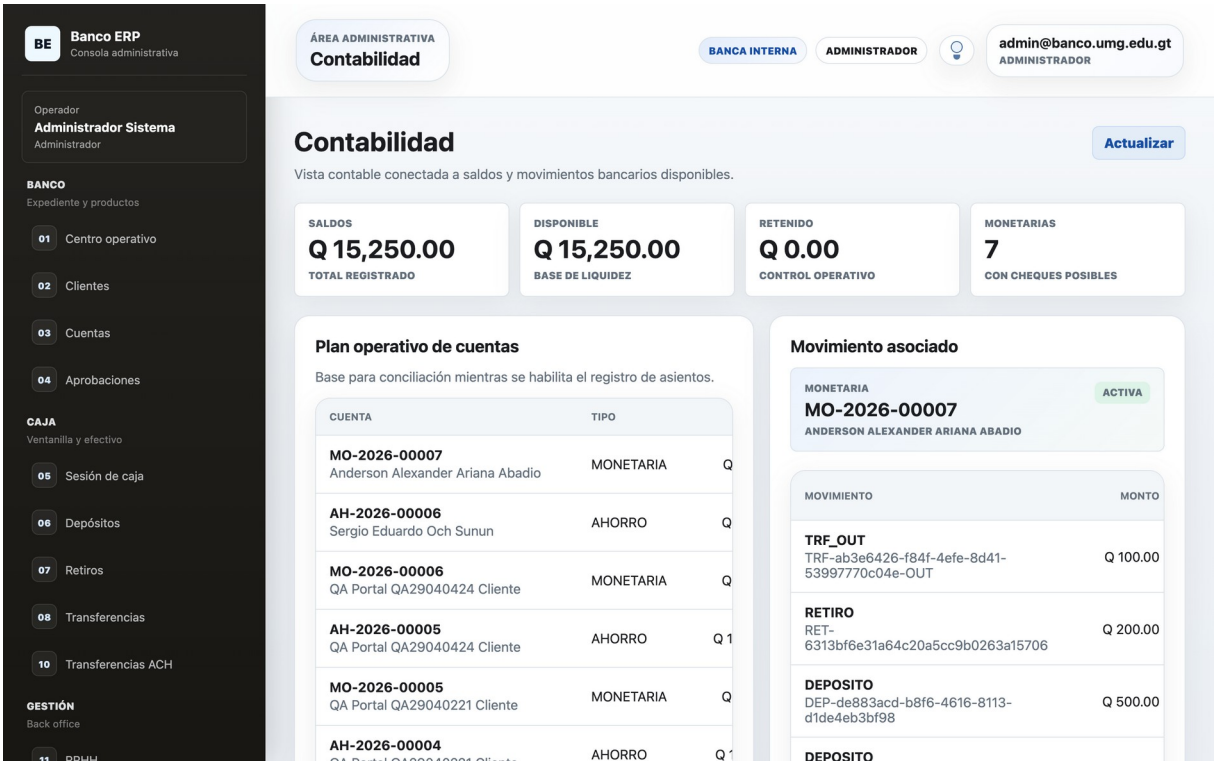


Figura A.18. Modulo de contabilidad. Captura del ambiente de QA, 15-09-2026.

Evidencia A.19 - Modulo de recursos humanos

Declarado fuera de alcance. Su unica interseccion con el nucleo (empleado activo asociado al operador) se cubre de forma indirecta como precondicion de las pruebas de caja.

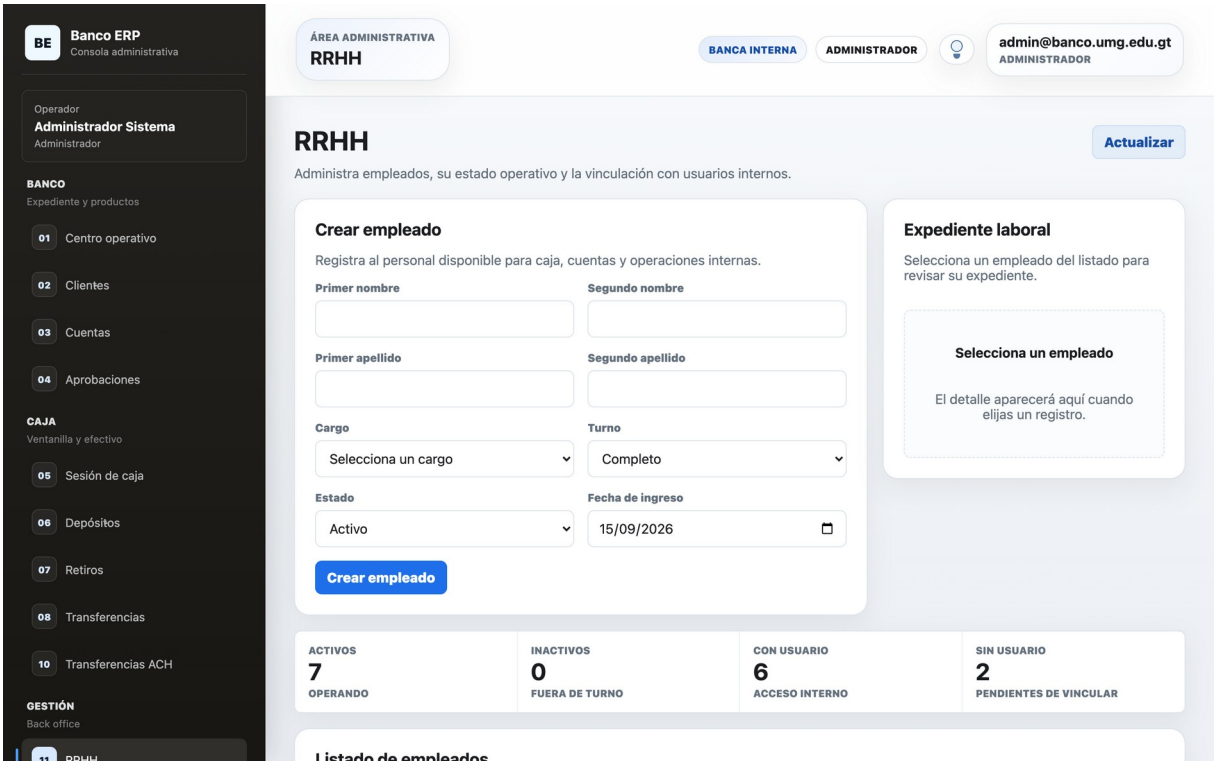


Figura A.19. Modulo de recursos humanos. Captura del ambiente de QA, 15-09-2026.

Evidencia A.20 - Catalogos y parametros del sistema

Declarado fuera de alcance por su bajo nivel de reglas de negocio.

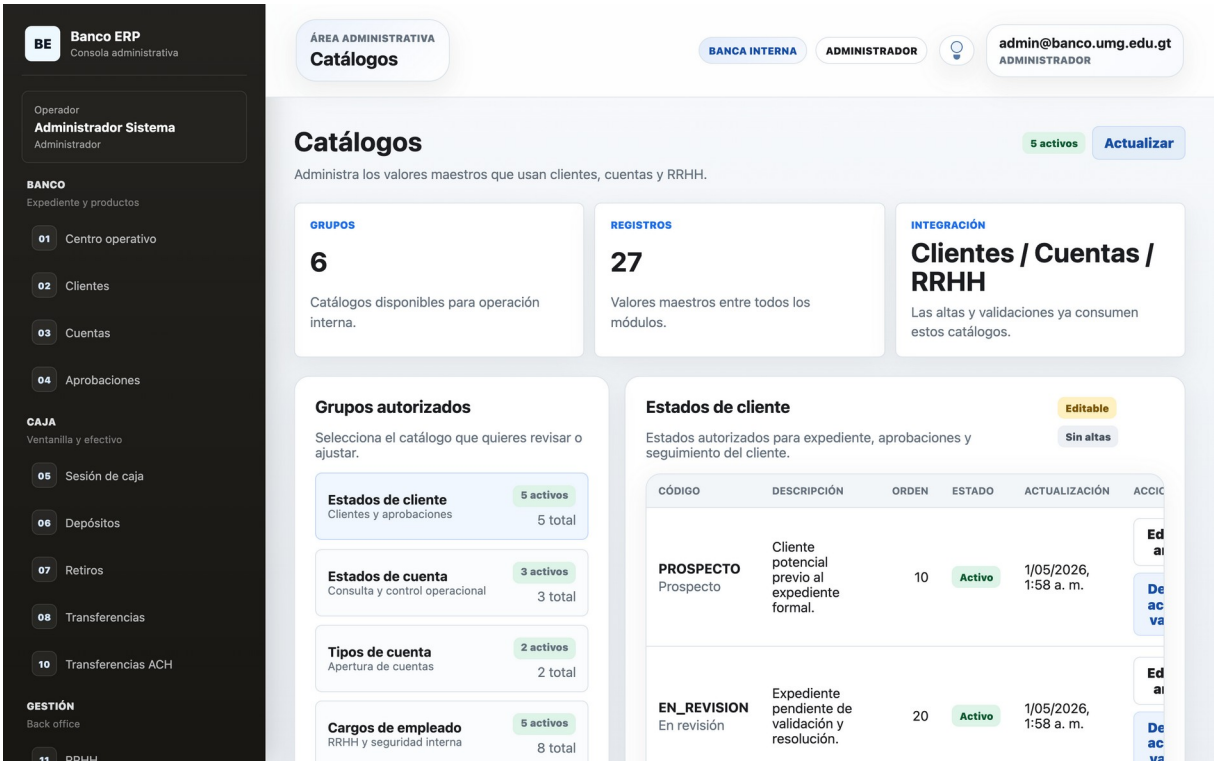


Figura A.20. Catalogos y parametros del sistema. Captura del ambiente de QA, 15-09-2026.

Evidencia A.21 - Vista responsive a 390 pixeles

Base para las pruebas de usabilidad acotadas de REQ-24. Sin mockups de referencia, la verificacion se limita a consistencia interna y ausencia de defectos evidentes de maquetacion.


Menu
Centro operativo
Business Intelligence interno con comparativas, estados, tendencias y lectura ejecutiva del ERP bancario.
Actualizar
CENTRO ANALÍTICO
Sin datos disponibles para construir lectura ejecutiva.
Vista detallada
Explorar clientes
EXPLORACIÓN
Opciones de análisis
Última actualización: Sin registro

Figura A.21. Vista responsive a 390 pixeles. Captura del ambiente de QA, 15-09-2026.

Anexo B. Registro de las verificaciones ejecutadas

Las siguientes comprobaciones se ejecutaron durante la fase de analisis para sustentar con evidencia los hallazgos reportados, en lugar de basarlos unicamente en la lectura del codigo. Documentarlas permite que cualquier integrante del equipo o el catedratico pueda reproducirlas.

No.	Verificacion ejecutada	Resultado obtenido	Sustenta
V-01	Levantamiento del ambiente completo con docker compose up -d --build y comprobacion de los cuatro servicios.	Frontend HTTP 200, InternalAPI HTTP 200 en /api/ping, PublicAPI operativa y MongoDB activo.	Seccion 13
V-02	Peticion GET a /api/ach/bancos sin token de autenticacion.	HTTP 200. El endpoint responde sin autenticacion y su contrato incluye el campo de contrasena de integracion.	H-05, R-01
V-03	Peticion GET a /api/clientes sin token de autenticacion, como control comparativo.	HTTP 401. Confirma que la proteccion existe en otros modulos y que la omision en ACH no es el comportamiento general del sistema.	H-05
V-04	Autenticacion con el campo 'identificador' frente a autenticacion con el campo 'username'.	HTTP 400 en el primer caso y HTTP 200 en el segundo, pese a que la interfaz rotula el campo como 'Usuario o correo'.	H-04
V-05	Intento de autenticacion con contrasena incorrecta desde la interfaz.	Mensaje 'Credenciales incorrectas. Intento 1 de 5', que revela el contador y confirma la divergencia entre el valor del ambiente (5) y el del codigo (3).	H-02, H-08
V-06	Ejecucion de la suite de pruebas unitarias con dotnet test.	13 pruebas ejecutadas, 13 exitosas, 0 fallidas. Cobertura limitada al canal ACH y a la autorizacion del banco externo.	H-12, BT-07
V-07	Revision de las advertencias emitidas durante la compilacion.	Tres dependencias con vulnerabilidades conocidas (dos de severidad alta y una moderada) sin que el proceso de construccion bloquee el despliegue.	H-09, R-12
V-08	Analisis del codigo de los procedimientos almacenados de transaccion.	sp_transferir_fondos no contiene ninguna referencia a limite_retiro_diario ni a monto_retirado_hoy; sp_retiro si las contiene y las aplica solo a cuentas AHORRO.	H-03, R-04
V-09	Exploracion guiada de los 20 modulos de la interfaz administrativa y del portal.	Ambiente sin datos de negocio: tablero sin informacion, saldos en Q0.00 y cero bancos ACH configurados.	H-15, R-15
V-10	Revision de la configuracion de origenes permitidos (CORS).	El analizador acepta separadores por coma y por punto y coma, por lo que la configuracion actual del ambiente es valida. Descarta una sospecha inicial del equipo.	REQ-22

La verificacion V-10 merece mencion: el equipo sospechaba inicialmente de un defecto de configuracion en el manejo de origenes permitidos, y la comprobacion demostro que no existia tal defecto. Se documenta de forma deliberada porque una sospecha descartada con evidencia tiene el mismo valor metodologico que un hallazgo confirmado: en ambos casos se sustituyo una suposicion por un hecho.